UNIVERSIDAD NACIONAL DEL ALTIPLANO

FACULTAD DE INGENIERÍA MECÁNICA ELÉCTRICA Y DE SISTEMAS

# Plan Integral de Ciberseguridad Institucional

## Caso de Aplicación: Universidad Nacional del Altiplano de Puno (UNAP)

**PRESENTADO POR:**
QUISPE CHATA CARLOS DAVID

**DOCENTE:**
TICONA YANQUI FIDEL ERNESTO

**SEMESTRE: IX**

**PUNO – 2026**

# ÍNDICE GENERAL


**Sección Preliminar: Declaración Ética, Marco Legal y Metodología** 1

**1 Datos Generales de la Entidad** 4

1.1 Ficha Técnica Institucional . . . . . 4
1.2 Ámbito de Aplicación y Cobertura Operativa . . . . . 4
1.3 Estructura Orgánica y Roles de Seguridad . . . . . 5

**2 Introducción** 6

2.1 Contexto y Relevancia Institucional . . . . . 6
2.2 Caracterización de la Superficie Expuesta Universitaria . . . . . 6
2.3 Ineficacia del Perímetro Tradicional y Nuevas Amenazas . . . . . 6
2.4 Enfoque Holístico de Ciberseguridad y Gobernanza . . . . . 6

**3 Finalidad y Objetivos** 8

3.1 Finalidad . . . . . 8
3.2 Objetivos del Plan . . . . . 9
3.2.1 Objetivo General . . . . . 9
3.2.2 Objetivos Específicos . . . . . 9

**4 Alcance del Plan** 10

4.1 Factor Humano y Organizacional . . . . . 10
4.2 Infraestructura Tecnológica y Hardware . . . . . 11
4.3 Redes y Comunicaciones . . . . . 11
4.4 Aplicaciones y Sistemas de Información . . . . . 12
4.5 Bases de Datos y Almacenamiento de Información . . . . . 12
4.6 Correo Institucional, Mensajería e Identidad Federada . . . . . 12
4.7 Servicios en la Nube y Proveedores Tecnológicos . . . . . 12

**5 Inventario y Clasificación de Activos** 13

5.1 Metodología de Identificación y Valoración . . . . . 13
5.2 Criterio de Clasificación Institucional . . . . . 14
5.3 Matriz Consolidada de Clasificación de Activos (UNAP) . . . . . 14
5.4 Conclusiones del Inventario de Activos y Brechas Identificadas . . . . . 16

**6 Análisis de Amenazas mediante STRIDE** 17

6.1 Metodología de Modelado STRIDE . . . . . 17

6.2 Selección y Alcance del Sistema Objetivo . . . 18
6.3 Diagrama de Flujo de Datos (DFD) y Límites de Confianza . . . 18
6.3.1 Elementos del DFD Nivel 1 . . . 18
6.3.2 Esquema Arquitectónico del DFD Nivel 1 . . . 19
6.4 Evaluación de Riesgos (Criterio DREAD Adaptado) . . . 20
6.5 Matriz de Análisis STRIDE del Sistema de Matrícula (UNAP) . . . 20
6.6 Procedimiento de Implementación de Controles Mitigadores . . . 22
6.6.1 A. Hardening Inmediato en Servidor Web Nginx (P-01) . . . 22
6.6.2 B. Aseguramiento del Manejo de Sesiones en ASP.NET Core (P-02 / D-01) . . . 22
6.6.3 C. Control Transaccional en Base de Datos (P-04 / D-02) . . . 24

**7 Inteligencia de Amenazas (Threat Intelligence) 25**

7.1 Fundamentación y Objetivos de la Vigilancia Institucional . . . 25
7.2 Ciclo Operativo de Threat Intelligence en la UNAP . . . 26
7.3 Taxonomía de Indicadores de Compromiso (Pirámide del Dolor) . . . 27
7.4 Producto Operativo: Boletín de Inteligencia de Amenazas . . . 28
7.5 Procedimiento de Actualización y Gobernanza . . . 29

**8 Análisis mediante MITRE ATT&CK 30**

8.1 Fundamentación y Marco Teórico de MITRE ATT&CK . . . 30
8.2 Procedimiento de Análisis y Evaluación de Brechas . . . 30
8.3 Matriz Institucional MITRE ATT&CK (UNAP) . . . 31
8.4 Especificación de Reglas de Detección e Implementación . . . 34
8.5 Acciones de Respuesta y Remediación por Táctica . . . 36

**9 Análisis mediante Cyber Kill Chain 37**

9.1 Fundamentación del Modelo Cyber Kill Chain . . . 37
9.2 Análisis Fase por Fase: Escenario de Intrusión Dirigida en la UNAP . . . 38
9.3 Mapa del Ciclo de Ataque y Controles Defensivos de Interrupción . . . 42
9.4 Diagrama del Punto de Quiebre Defensivo (Kill-Switch) . . . 44

**10 Implementación de Zero Trust (Confianza Cero) 45**

10.1 Principios Rectores y Filosofía Arquitectónica en la UNAP . . . 45
10.2 Acciones Estratégicas por los Cinco Pilares de Zero Trust . . . 46
10.3 Matriz Institucional de Roles, Usuarios y Permisos (Modelo RBAC / Zero Trust) . . . 49
10.4 Procedimiento Operativo de Verificación y Revocación de Accesos . . . 51

**11 Matriz de Gestión y Gobernanza – NIST CSF 2.0 52**

11.1 Fundamentación del Marco NIST CSF 2.0 en la UNAP . . . 52
11.2 Matriz Integral NIST CSF 2.0 Aplicada a la UNAP . . . 53
11.3 Articulación Operativa con las Metodologías del Plan . . . 55

**12 Controles Técnicos de Seguridad 56**

12.1 Catálogo de Especificación Técnica de Controles . . . 56
12.2 Configuración de Endurecimiento Web en Servidores Nginx . . . 57

**13 Gestión y Respuesta a Incidentes** 58

13.1 Procedimiento Operativo Estándar . . . . . 58
13.2 Canales Institucionales de Notificación Rápida . . . . . 58
13.3 Clasificación de Incidentes por Tipo de Amenaza . . . . . 59

**14 Capacitación y Concientización** 60

14.1 Campaña Permanente de Concientización . . . . . 60
14.2 Simulaciones Semestrales de Phishing Controlado . . . . . 60
14.3 Módulos de Formación Especializada para Personal Técnico . . . . . 60

**15 Indicadores de Cumplimiento (Métricas y KPIs)** 62

15.1 Cuadro de Mando de Métricas de Ciberseguridad . . . . . 62

**Anexos: Evidencias y Documentación de Soporte** 63

# DECLARACIÓN ÉTICA, MARCO LEGAL Y METODOLOGÍA

**Sección Preliminar: Marco de Integración Metodológica Institucional**

**NIST CSF 2.0** (Gestión) $\longrightarrow$ **STRIDE** (Amenazas) $\longrightarrow$ **MITRE ATT&CK** (TTPs)
$\longrightarrow$ **Threat Intelligence** (Vigilancia) $\longrightarrow$ **Cyber Kill Chain** (Fases) $\longrightarrow$ **Zero Trust** (Controles)

## 1 Declaración Ética y de No Intrusión

El presente documento, titulado **"Plan de Ciberseguridad Institucional de la Universidad Nacional del Altiplano de Puno (UNAP)"**, ha sido formulado exclusivamente con fines de investigación académica, auditoría defensiva (*Blue Team*) y diseño de arquitectura de seguridad (*Security by Design*).

Los autores/evaluadores declaran bajo juramento de integridad profesional y académica:

- **Ausencia de Pruebas Intrusivas:** En ninguna etapa de la elaboración de este plan se llevaron a cabo análisis de penetración activos (*Pentesting*), pruebas de denegación de servicio (DoS/DDoS), inyecciones de código malicioso, ataques de fuerza bruta contra paneles autenticados, ni explotación de vulnerabilidades en los sistemas de información institucionales.
- **Preservación de la Continuidad Operativa:** Ninguna de las consultas realizadas generó alteración, interrupción, degradación de rendimiento o indisponibilidad en los servicios informáticos de la UNAP.
- **Respeto a la Privacidad de los Datos:** No se accedió, extrajo, manipuló ni divulgó información personal, financiera o académica protegida perteneciente a estudiantes, docentes, personal administrativo o autoridades de la universidad. El acceso a las interfaces analizadas se efectuó dentro del marco de sesiones ordinarias y legítimas provistas a los miembros de la comunidad universitaria.
- **Finalidad Propositiva y Mitigadora:** Los hallazgos y evidencias recopilados tienen el único propósito de justificar técnicamente la necesidad de implementar controles preventivos bajo el marco NIST CSF 2.0, mitigar amenazas modeladas con STRIDE, mapear tácticas adversarias en MITRE ATT&CK e implementar un modelo de Confianza Cero (*Zero Trust*) que eleve la postura de ciberseguridad de la UNAP.

## 2 Marco Legal Aplicable en el Estado Peruano

El desarrollo de este plan y la justificación de los controles técnicos se fundamentan en el marco normativo nacional vigente en materia de gobernanza digital, seguridad de la información y delitos informáticos:

- **Ley N° 30096 (Ley de Delitos Informáticos) y su modificatoria Ley N° 30171:** La metodología empleada respeta irrestrictamente los artículos referidos al acceso ilícito (Art. 2), atentado a la integridad de datos y sistemas informáticos (Arts. 3 y 4) y fraude informático (Art. 8). Al no existir intrusión ni vulneración de medidas de seguridad perimetral, la recolección de telemetría pasiva no transgrede esta ley.
- **Decreto de Urgencia N° 006-2020 (Decreto de Urgencia que crea el Sistema Nacional de Transformación Digital):** Establece como deber de todas las entidades públicas peruanas, incluidas las universidades nacionales, la implementación de un Marco de Seguridad y Confianza Digital que proteja los activos de información del Estado.
- **Decreto Supremo N° 029-2021-PCM (Reglamento del Decreto Legislativo N° 1412, Ley de Gobierno Digital):** Dispone lineamientos mandatorios para la gestión de riesgos de seguridad digital en las plataformas de servicios digitales públicos.
- **Ley N° 29733 (Ley de Protección de Datos Personales) y su Reglamento (D.S. N° 003-2013-JUS):** Regula el tratamiento y la confidencialidad de los bancos de datos que albergan identificadores personales de estudiantes y trabajadores en los sistemas de matrícula y recursos humanos de la UNAP.
- **Resoluciones y Directivas de la Secretaría de Gobierno y Transformación Digital (SGTD - PCM):** En su calidad de ente rector nacional en ciberseguridad y coordinador del Centro Nacional de Seguridad Digital (CSIRT Nacional).

## 3 Metodología de Evaluación y Recolección de Evidencias

Para la identificación de brechas y sustento del análisis de amenazas, se utilizó estrictamente una metodología de evaluación pasiva de fuentes abiertas (OSINT) e inspección de cliente en comunicaciones estándar, desglosada en los siguientes procedimientos:

### A Inteligencia de Fuentes Abiertas y Consulta DNS Pasiva (OSINT)

- **Descubrimiento de Superficie Expuesta:** Se consultaron los registros públicos de Transparencia de Certificados SSL/TLS (*Certificate Transparency Logs* vía `crt.sh`), identificando la existencia de más de un centenar de subdominios registrados bajo la zona `*.unap.edu.pe` sin interactuar directamente con los hosts objetivo.
- **Auditoría de Registros de Correo Institucional:** Se ejecutaron peticiones estándar de resolución de nombres DNS (tipo TXT) mediante la herramienta de diagnóstico de sistemas operativos `nslookup` apuntando a servidores DNS públicos, con el fin de evaluar la postura de los registros de autenticación de correo:
  - Verificación de la directiva SPF (*Sender Policy Framework*) en el dominio raíz `unap.edu.pe`.
  - Verificación de la presencia o ausencia de políticas de alineación DMARC (*Domain-based Message Authentication, Reporting, and Conformance*) en el nodo `_dmarc.unap.edu.pe`.

### B Inspección Pasiva del Lado del Cliente (Client-Side Inspection)

- **Análisis de Cabeceras HTTP de Respuesta:** Mediante las herramientas de desarrollo web del navegador (DevTools - F12 / RFC 7230) en el marco de una navegación regular autorizada hacia los portales `https://matricula.unap.edu.pe` y `https://campus.unap.edu.pe`, se examinaron los encabezados enviados de forma pública por los servidores web:
  - Exposición de metadatos de software y versión en el encabezado `Server` (`nginx/1.16.1`).
  - Comprobación del estado de la directiva de transporte seguro HSTS (`Strict-Transport-Security`).
  - Inspección de cabeceras de defensa contra ataques visuales y de contexto (`X-Frame-Options`, `Content-Security-Policy`, `X-Content-Type-Options`).
- **Inspección de Atributos de Almacenamiento de Sesión:** Revisión de las banderas de seguridad asignadas a las cookies de autenticación generadas por el entorno de desarrollo (.NET Core: `.AspNetCore.Cookies`, `CookieTempDataProvider`) para evaluar la presencia de los atributos `HttpOnly`, `Secure` y `SameSite`.

### C Modelado de Amenazas y Simulación Teórica (Tabletop Simulation)

La articulación de las amenazas no provino de incidentes forzados en producción, sino del cruce sistemático entre las vulnerabilidades de configuración verificadas pasivamente y las matrices estandarizadas de la industria (STRIDE de Microsoft, la taxonomía de técnicas de MITRE ATT&CK Enterprise v14 y las 7 fases de intrusión de la Cyber Kill Chain de Lockheed Martin).

**Nota de Rigor Académico:** Con este marco queda formalmente establecida la rigurosidad técnica, ética y legal del documento frente a cualquier comisión evaluadora o autoridad universitaria.

# 1 DATOS GENERALES DE LA ENTIDAD

En este capítulo se formalizan los datos institucionales de la entidad universitaria, las dependencias responsables del gobierno y administración de la seguridad digital, el marco temporal de vigencia y el alcance operativo del plan.

## Sec 1.1 Ficha Técnica Institucional

| Campo | Detalle Institucional |
|---|---|
| **Nombre de la Entidad** | Universidad Nacional del Altiplano de Puno (UNAP). |
| **Unidad Responsable** | Oficina de Tecnologías de la Información (OTI) — Unidad de Redes, Comunicaciones y Seguridad Informática. |
| **Responsable del Plan** | ▪ Jefe de la Oficina de Tecnologías de la Información (OTI).<br>▪ Oficial de Seguridad de la Información (CISO Institucional / Delegado de Seguridad Digital). |
| **Periodo de Vigencia** | 2026 – 2027 (vigencia de doce meses, sujeta a evaluación semestral de madurez y revisión anual obligatoria). |
| **Fecha de Aprobación** | Octubre de 2026 (conforme a los mecanismos de aprobación institucional mediante Resolución Rectoral). |
| **Ámbito de Aplicación** | Sede Central (Av. Floral N° 1153), 20 Facultades, 36 Escuelas Profesionales, Posgrado, Órganos de Alta Dirección y Data Center OTI. |

## Sec 1.2 Ámbito de Aplicación y Cobertura Operativa

El alcance del presente plan abarca la totalidad de las dependencias físicas, académicas, directivas e infraestructuras de datos de la institución:

- **Sede Central y Campus Universitario:** Ciudad Universitaria ubicada en la Av. Floral N° 1153, Puno, incluyendo edificios administrativos, aulas magnas y laboratorios centrales.
- **Dependencias Académicas:** 20 Facultades, 36 Escuelas Profesionales, la Escuela de Posgrado y los Centros de Producción de Bienes y Servicios universitarios.

- **Órganos de Alta Dirección y Apoyo Administrativo:** Rectorado, Vicerrectorado Académico (VRA), Vicerrectorado de Investigación (VRI), Dirección General de Administración (DGA), Dirección de Registro y Matrícula, y Secretaría General.
- **Infraestructura de Datos:** Centro de Procesamiento de Datos (Data Center OTI), nodos perimetrales de telecomunicaciones, plataformas en nube institucional y servicios web federados.

## Sec 1.3 Estructura Orgánica y Roles de Seguridad

La ejecución y supervisión del presente plan involucra a los siguientes actores clave de la gobernanza universitaria:

1. **Alta Dirección (Rectorado y Vicerrectorados):** Aprobación presupuestal, respaldo normativo y asignación de prioridades estratégicas para el fortalecimiento de la infraestructura digital.
2. **Oficina de Tecnologías de la Información (OTI):** Conducción técnica general, administración del Data Center institucional y despliegue de las políticas de seguridad.
3. **Unidad de Redes y Seguridad Informática / CSIRT-UNAP:** Monitoreo continuo de eventos de seguridad, gestión perimetral de firewalls, sistemas de detección y respuesta inmediata ante incidentes cibernéticos.

# 2 INTRODUCCIÓN

## Sec 2.1 Contexto y Relevancia Institucional

La Universidad Nacional del Altiplano de Puno custodia, gestiona y transfiere permanentemente el patrimonio digital, académico, científico y administrativo de más de 20,000 usuarios activos entre estudiantes, investigadores, plana docente y personal directivo-administrativo. La progresiva consolidación de servicios digitales (como el Sistema de Matrícula en línea, la plataforma de Campus Virtual Moodle, el Sistema de Trámite Documentario SITRAD y los repositorios institucionales de investigación) ha desplazado los límites del campus físico hacia un ecosistema hiperconectado, distribuido y expuesto permanentemente a Internet.

## Sec 2.2 Caracterización de la Superficie Expuesta Universitaria

Sin embargo, esta apertura operativa ha expandido correlativamente la superficie de exposición institucional. Las auditorías pasivas y de reconocimiento externo realizadas sobre el dominio `unap.edu.pe` constatan una arquitectura heterogénea donde coexisten más de un centenar de subdominios registrados, servidores web con capas de proxy inverso desactualizadas (como `nginx/1.16.1` en el entorno de matrícula), mecanismos de transporte seguro sin directivas estrictas de mitigación frente a interceptaciones (ausencia de `Strict-Transport-Security` — HSTS) y una vulnerable postura de confianza en la mensajería institucional evidenciada por la inexistencia de directivas DMARC (`NXDOMAIN`) y mecanismos permisivos de Sender Policy Framework (SPF: `~all`).

## Sec 2.3 Ineficacia del Perímetro Tradicional y Nuevas Amenazas

En este escenario, el modelo clásico de “seguridad perimetral” —basado en la premisa ingenua de que los recursos dentro de la red interna son confiables por defecto— resulta completamente ineficaz. La sofisticación de las amenazas actuales, tales como campañas de Spear-Phishing dirigidas al personal administrativo en ventanas críticas de matrícula, infecciones por ransomware que paralizan servidores de gestión pública, y técnicas de movimiento lateral basadas en el abuso de identidades válidas, exige la formulación de una estrategia integral, moderna y resiliente.

## Sec 2.4 Enfoque Holístico de Ciberseguridad y Gobernanza

El presente Plan de Ciberseguridad Institucional adopta un enfoque multifacético y holístico: acoge al estándar NIST Cybersecurity Framework (CSF) 2.0 como el marco sombrilla de gobernanza; integra el modelado temprano

de amenazas mediante STRIDE para los flujos de software; correlaciona los comportamientos y tácticas adversarias observadas con la taxonomía MITRE ATT&CK Enterprise; incorpora la vigilancia contextual de Threat Intelligence; diseña barreras de contención escalonadas mediante la Cyber Kill Chain; y materializa controles estrictos bajo la doctrina de Zero Trust (*"Nunca confiar, siempre verificar de manera explícita y asumir la brecha"*). Con ello, la UNAP alinea su gestión tecnológica con las exigencias del Decreto de Urgencia N° 006-2020 y asegura la continuidad irrestricta de su servicio educativo superior.

# 3 FINALIDAD Y OBJETIVOS

En este capítulo se define el propósito estratégico del plan de seguridad digital y los objetivos medibles formulados para la UNAP.

## Sec 3.1 Finalidad

La finalidad del presente Plan Institucional de Ciberseguridad es establecer, normar y articular un conjunto coordinado de medidas técnicas, organizacionales, normativas y procedimentales orientadas a prevenir, identificar, proteger, detectar, responder y recuperarse eficazmente frente a incidentes, amenazas y ataques informáticos que atenten contra la confidencialidad, integridad y disponibilidad del ecosistema tecnológico de la Universidad Nacional del Altiplano de Puno.

Para alcanzar dicha finalidad, el plan formaliza una arquitectura de defensa en profundidad mediante la sinergia de marcos y metodologías de referencia internacional:

- **Gobernanza Estratégica (NIST CSF 2.0):** Institucionalizar la ciberseguridad a nivel transversal en la universidad, estructurando la toma de decisiones, la asignación de recursos y la gestión integral de riesgos tecnológicos dentro de las seis funciones directivas: Gobernar, Identificar, Proteger, Detectar, Responder y Recuperar.
- **Modelado Preventivo de Software (STRIDE):** Analizar y mitigar sistemáticamente los vectores de Suplantación (*Spoofing*), Manipulación (*Tampering*), Repudio (*Repudiation*), Fuga de Información (*Information Disclosure*), Denegación de Servicio (*Denial of Service*) y Elevación de Privilegios (*Elevation of Privilege*) en las aplicaciones críticas desarrolladas y operadas por la OTI (con especial énfasis en el flujo `matricula.unap.edu.pe`).
- **Vigilancia Proactiva (Threat Intelligence):** Monitorizar de forma continua indicadores de compromiso (IoCs), registros de suplantación de dominio (*typosquatting*), tácticas dirigidas contra el sector público peruano y vulnerabilidades de día cero para anticiparse a los vectores de intrusión.
- **Caracterización Técnica del Adversario (MITRE ATT&CK):** Mapear el comportamiento real y las tácticas, técnicas y procedimientos (TTPs) de los atacantes, habilitando capacidades analíticas en registros de auditoría y telemetría de red para transformar los incidentes en reglas de detección temprana en herramientas SIEM.
- **Ruptura del Vector de Intrusión (Cyber Kill Chain):** Diseñar controles específicos y puntos de quiebre defensivo en cada uno de los siete eslabones lineales del ataque, impidiendo que una amenaza en fase de reconocimiento o entrega (como el phishing facilitado por la ausencia de DMARC) culmine en la explotación o el secuestro de información sensible.
- **Controles Operativos Estrictos (Zero Trust Architecture):** Reemplazar la confianza implícita por una verificación continua y granular sobre identidades (MFA obligatorio), dispositivos de acceso, segmentación lógica de redes (VLANs), aplicaciones web blindadas y cifrado mandatorio de datos académicos y financieros, tanto en reposo como en tránsito.

## Sec 3.2 Objetivos del Plan

### 3.2.1 Objetivo General

Fortalecer de forma integral la postura de seguridad de la información y la resiliencia operativa de la Universidad Nacional del Altiplano de Puno (UNAP), mediante la identificación rigurosa de activos críticos, el modelado sistemático de amenazas, la implementación de controles defensivos bajo el estándar de Confianza Cero (Zero Trust) y el establecimiento de capacidades institucionales estandarizadas de detección, respuesta y recuperación continua articuladas bajo el marco NIST CSF 2.0.

### 3.2.2 Objetivos Específicos

1. **Identificar y clasificar los activos de información:** Catalogar exhaustivamente el 100 % de los recursos tecnológicos, servidores, bases de datos, redes y servicios web asociados al dominio `unap.edu.pe`, estratificando su nivel de criticidad (Crítico, Alto, Medio, Bajo) conforme al impacto sobre la continuidad del servicio educativo y la confidencialidad de los datos.
2. **Determinar amenazas y vulnerabilidades arquitectónicas:** Ejecutar el modelado preventivo de amenazas mediante la metodología STRIDE sobre los sistemas críticos de la universidad (priorizando el flujo de matrícula y campus virtual), identificando debilidades de configuración, obsolescencia de software (como `nginx/1.16.1`) y ausencia de directivas de protección en el transporte (`Strict-Transport-Security`).
3. **Analizar y correlacionar las técnicas empleadas por atacantes:** Caracterizar el comportamiento potencial de ciberadversarios en el contexto universitario mediante la matriz MITRE ATT&CK Enterprise, traduciendo las técnicas y procedimientos observados en reglas formales de visibilidad, auditoría y monitoreo de eventos.
4. **Detectar amenazas reales mediante inteligencia proactiva:** Institucionalizar un flujo operativo de Threat Intelligence para monitorizar activamente campañas de Spear-Phishing, registros fraudulentos de dominios (*typosquatting*), abuso de la reputación institucional derivado de la ausencia de DMARC y explotación de vulnerabilidades conocidas (CVEs).
5. **Implementar controles preventivos y perimetrales:** Desplegar mecanismos de mitigación perimetral (Web Application Firewall - WAF, inspección de cabeceras, políticas DNS estrictas SPF: `-all` y DMARC: `p=reject`) y capacidades de protección en estaciones de trabajo y servidores mediante soluciones EDR centralizadas.
6. **Fortalecer el gobierno de identidades y el control de accesos:** Implementar la directriz de Autenticación Multifactor (MFA) obligatoria para personal administrativo, directivo y docente, combinada con políticas de privilegios mínimos (*Principle of Least Privilege*) y asignación estricta de roles (RBAC) en las plataformas académicas.
7. **Reducir los riesgos de exposición y fuga de datos personales:** Blindar los canales de transmisión y repositorios que albergan calificaciones, historiales académicos y datos de identificación personal (DNI, registros biométricos), garantizando el cumplimiento irrestricto de la Ley N° 29733 (Ley de Protección de Datos Personales).
8. **Mejorar la capacidad de respuesta y resiliencia ante incidentes:** Formalizar el Equipo de Respuesta a Incidentes de Seguridad Digital de la UNAP (CSIRT-UNAP), definiendo procedimientos operativos estandarizados (*Playbooks*) para minimizar los tiempos medios de detección (MTTD) y contención (MTTR), asegurando la restauración íntegra de servicios mediante copias de seguridad inmutables (estrategia 3-2-1).

# 4 ALCANCE DEL PLAN

El presente Plan Institucional de Ciberseguridad es de aplicación obligatoria, transversal y vinculante para todas las dependencias académicas, de investigación, administrativas y operativas de la Universidad Nacional del Altiplano de Puno.

Su ámbito de cobertura se desglosa en los siguientes dominios clave de gobernanza y protección tecnológica:

| MATRIZ SINTÉTICA DE ALCANCE INSTITUCIONAL | | |
|---|---|---|
| **Factor Humano** | **Infraestructura** | **Lógica y Datos** |
| ▪ Estudiantes<br>▪ Plana Docente<br>▪ Administrativos<br>▪ Terceros y Soporte | ▪ Data Center OTI<br>▪ Estaciones Administrativas<br>▪ Labs de Cómputo<br>▪ Core de Red y WAN | ▪ Apps Web (Matrícula/Campus)<br>▪ Bases de Datos (PostgreSQL/SQL)<br>▪ Correo (`@unap.edu.pe`)<br>▪ Servicios Cloud y Repositorio |

## Sec 4.1 Factor Humano y Organizacional

- **Comunidad Estudiantil:** Más de 19,000 alumnos matriculados en programas de pregrado, posgrado y segunda especialidad que hacen uso de credenciales de acceso a portales institucionales.
- **Plana Docente e Investigadores:** Profesores nombrados y contratados con facultades de registro de evaluaciones, gestión curricular e investigación en laboratorios.
- **Personal Administrativo y Directivo:** Autoridades universitarias (Rectorado, Decanatos), personal de tesorería, recaudación, recursos humanos, mesa de partes y logística que gestiona información clasificada y flujos financieros.
- **Proveedores y Contratistas Externos:** Empresas y consultores que brindan servicios de desarrollo de software, mantenimiento de fibra óptica, soporte de hardware o licenciamiento institucional.

## Sec 4.2 Infraestructura Tecnológica y Hardware

- **Centro de Procesamiento de Datos (Data Center OTI):** Todos los servidores físicos, chasis blade, sistemas de almacenamiento masivo (NAS/SAN), gabinetes de comunicaciones y sistemas de respaldo energético (UPS/Grupo electrógeno) ubicados en el campus central (Av. Floral).
- **Entornos de Virtualización:** Nodos hipervisores (VMware ESXi, Proxmox, Hyper-V) y contenedores donde se ejecutan los servicios centrales de la universidad.
- **Estaciones de Trabajo Institucionales:** Computadoras de escritorio y portátiles asignadas a oficinas administrativas, decanatos y dependencias funcionales de la universidad.
- **Laboratorios de Cómputo Académicos:** Toda la infraestructura de estaciones de trabajo ubicadas en las 20 facultades destinadas a prácticas de pregrado y posgrado.

## Sec 4.3 Redes y Comunicaciones

- **Núcleo de Red (Core Network):** Switches de capa de distribución y núcleo, routers de borde y enlaces troncales de fibra óptica interfacultades en la Ciudad Universitaria.
- **Comunicaciones Inalámbricas (WLAN):** Puntos de acceso (*Access Points*) y controladores Wi-Fi desplegados en áreas comunes, facultades y pabellones administrativos (segmentando el tráfico de invitados del tráfico académico).
- **Perímetro y Conectividad Remota:** Enlaces de salida a Internet gestionados por la OTI, enlaces dedicados WAN hacia centros experimentales (Camacani, Illpa) y canales de acceso remoto seguro (VPNs).

## Sec 4.4 Aplicaciones y Sistemas de Información

- **Sistemas Académicos Críticos:** Plataforma de Matrícula e Intranet (`matricula.unap.edu.pe`), Plataforma de Campus Virtual Moodle (`campus.unap.edu.pe`, `aulavirtual.unap.edu.pe`) y subsistemas asociados a la Dirección General de Asuntos Académicos.
- **Sistemas de Gestión Pública y Trámite:** Sistema de Trámite Documentario SITRAD (`tramiteapp.unap.edu.pe`), Mesa de Partes Digital y Portal de Transparencia Universitaria.
- **Sistemas de Soporte y Control Institucional:** Módulos de recaudación y pagos de tesorería, portal de Admisión (`admision.unap.edu.pe`), servicios biométricos de personal (`apibiometrico.unap.edu.pe`) y repositorio DSpace (`repositorio.unap.edu.pe`).
- **Entornos de Desarrollo y Homologación:** Servidores intermedios (`dev.*`, `dev2.*`, `prue1.*`) expuestos o internos utilizados por el equipo de sistemas para el despliegue de nuevas funcionalidades.

## Sec 4.5 Bases de Datos y Almacenamiento de Información

- **Motores de Bases de Datos Relacionales:** Servidores PostgreSQL, Microsoft SQL Server, MySQL y Oracle que resguardan tablas de matrículas, actas de notas, legajos de personal docente y registros de pago.
- **Repositorios de Almacenamiento Estructurado y No Estructurado:** Expedientes digitalizados, resoluciones rectorales, tesis de grado y respaldos de configuración de red.

## Sec 4.6 Correo Institucional, Mensajería e Identidad Federada

Todo el dominio de correo `@unap.edu.pe` desplegado sobre plataformas de colaboración en la nube (Google Workspace / Microsoft 365), incluyendo los mecanismos de autenticación única (*Single Sign-On* - SSO), repositorios Drive compartidos y listas de distribución oficial institucional.

## Sec 4.7 Servicios en la Nube y Proveedores Tecnológicos

- **Instancias en la Nube Pública:** Cargas de trabajo en AWS, Azure y Google Cloud, servicios de alojamiento externo, pasarelas de pago bancarias y certificados SSL/TLS emitidos para el dominio de la universidad.
- **Gestión de Terceros y Proveedores:** Contratos de servicios tecnológicos que estipulan acuerdos de confidencialidad (NDA), gestión controlada de accesos remotos y cláusulas de responsabilidad en ciberseguridad conforme al estándar Zero Trust.

# 5 INVENTARIO Y CLASIFICACIÓN DE ACTIVOS

En este capítulo se presenta el inventario exhaustivo de activos de información de la UNAP, la metodología de valoración basada en la tríada CID, los criterios de criticidad y la matriz consolidada de los 20 activos centrales de la universidad.

## Sec 5.1 Metodología de Identificación y Valoración

Para la elaboración del inventario y la matriz de clasificación de activos de la Universidad Nacional del Altiplano de Puno (UNAP), se combinó el relevamiento de activos físicos del Centro de Procesamiento de Datos (Data Center OTI) y dependencias administrativas con una auditoría pasiva de la superficie de exposición externa mediante registros públicos de Transparencia de Certificados SSL/TLS (*Certificate Transparency Logs* vía `crt.sh`). Este procedimiento permitió registrar los servicios web, paneles de administración, bases de datos y nodos de red asociados a la zona DNS `unap.edu.pe`.

La valoración de cada activo se determinó evaluando el impacto que sufriría la universidad ante la pérdida o degradación de las tres dimensiones de la seguridad de la información:

- **Confidencialidad (C):** Impacto derivado de la divulgación no autorizada de datos personales de estudiantes/docentes, registros financieros o propiedad intelectual (conforme a la Ley N° 29733).
- **Integridad (I):** Impacto provocado por la alteración no autorizada de calificaciones, actas académicas, resoluciones rectorales o tablas contables.
- **Disponibilidad (D):** Impacto operativo generado por la interrupción temporal o permanente del servicio durante periodos críticos (semanas de matrícula, procesamiento de planillas o sesiones de Consejo Universitario).

Cada dimensión se califica en una escala ordinal de 1 a 4:

- **1 (Bajo):** Afectación mínima o insignificante; el daño es subsanable de forma inmediata con impacto operativo nulo.
- **2 (Medio):** Pérdida de eficiencia operativa en áreas no esenciales o exposición de datos institucionales de carácter público.
- **3 (Alto):** Afectación severa a procesos administrativos/financieros con consecuencias normativas o daño reputacional institucional significativo.
- **4 (Crítico):** Parálisis total de las actividades académicas/administrativas, alteración masiva de actas oficiales o contingencia legal directa frente a SUNEDU y entes del Estado.

## Sec 5.2 Criterio de Clasificación Institucional

El nivel global de criticidad asignado al activo corresponde al valor máximo obtenido entre sus dimensiones individuales:

$$\text{Criticidad} = \max(C,\ I,\ D)$$

Este criterio garantiza que un activo con exigencia crítica en una sola dimensión (por ejemplo, integridad absoluta de notas académicas) reciba el tratamiento prioritario que le corresponde:

- **Crítico (Nivel 4):** Activos esenciales para la continuidad académica, la recaudación y la gobernanza de la UNAP. Su compromiso paraliza la institución.
- **Alto (Nivel 3):** Sistemas de trámite documentario, recaudación, recursos humanos y servicios de comunicación oficial.
- **Medio (Nivel 2):** Plataformas de divulgación científica, repositorios documentales, portales de escuelas profesionales y estaciones de trabajo administrativas.
- **Bajo (Nivel 1):** Sitios web puramente informativos, blogs de eventos y páginas estáticas sin interacción con bases de datos internas.

## Sec 5.3 Matriz Consolidada de Clasificación de Activos (UNAP)

A continuación, se detalla el inventario estructurado de los 20 activos de información evaluados en el ecosistema digital de la UNAP:

| ID | Nombre | Tipo | Endpoint / Ubic. | Custodio | C | I | D | Clasif. | Justificación de Criticidad |
|---|---|---|---|---|---|---|---|---|---|
| **ACT-01** | Base de Datos Académica | Base de Datos (PostgreSQL / Oracle) | Data Center OTI (VLAN 10) | Admin. BD / Dir. Asuntos Acad. | 4 | 4 | 4 | **Crítico** | Contiene el historial de notas, créditos y matrículas de más de 19,000 alumnos; daño legal irreversible. |
| **ACT-02** | Sistema de Matrícula | App Web / API (.NET Core) | `matricula.unap.edu.pe` | OTI / Unidad de Sistemas | 4 | 4 | 4 | **Crítico** | Proceso medular de inicio de semestre; expuesto a picos y alteración de vacantes. |
| **ACT-03** | Campus Virtual Moodle | LMS (PHP / Linux) | `campus.unap.edu.pe` | OTI / Educación Virtual | 3 | 4 | 4 | **Crítico** | Clases, tareas y evaluaciones en línea de pre y posgrado; paraliza la docencia si cae. |
| **ACT-04** | Enlaces WAN Switch Core | Redes y Comunicaciones | Data Center OTI Campus Central | Unidad de Redes y Telecom. | 2 | 4 | 4 | **Crítico** | Troncal de fibra y enrutamiento borde; su falla aísla los servidores internos. |
| **ACT-05** | Respaldo Local (NAS) | Almacenamiento Respaldo | Data Center OTI (VLAN 15) | Administrador Servidores OTI | 4 | 4 | 4 | **Crítico** | Última línea de defensa institucional ante ataques de ransomware catastróficos. |
| **ACT-06** | Correo y Suite Cloud | SaaS / Cloud | `@unap.edu.pe` (Google / M365) | OTI / Secretaría General | 4 | 3 | 3 | **Alto** | Identidad federada (SSO) y canal legal; vector principal de ataques de Spear-Phishing. |
| **ACT-07** | Trámite (SITRAD) | App Web / BD | `tramiteapp.unap.edu.pe` | Secretaría General / Trámite | 3 | 4 | 3 | **Alto** | Gestión de resoluciones de Consejo Universitario y decretos con valor legal vinculante. |

| ID | Nombre | Tipo | Endpoint / Ubic. | Custodio | C | I | D | Clasif. | Justificación de Criticidad |
|---|---|---|---|---|---|---|---|---|---|
| **ACT-08** | Sistema de Admisión | App Web / BD | `admision.unap.edu.pe` | Comisión Permanente Admisión / OTI | 4 | 4 | 4 | **Crítico** | Pagos, vacantes y resultados de exámenes; alto escrutinio público y riesgo de fraude. |
| **ACT-09** | Tesorería y Caja | Software Financiero / BD | `tesoreria.unap.edu.pe` | Dir. General Administración | 4 | 4 | 3 | **Alto** | Recaudación de tasas educativas, conciliaciones bancarias y transferencias del MEF. |
| **ACT-10** | Planillas y Remunerac. | Software RRHH / BD | `remuneraciones.unap.edu.pe` | Oficina de Recursos Humanos | 4 | 4 | 2 | **Alto** | Custodia cuentas bancarias y haberes de docentes y administrativos (Ley N° 29733). |
| **ACT-11** | Marcación Biométrica | API REST / Microservicio | `apibiometrico.unap.edu.pe` | Oficina de Personal / OTI | 3 | 3 | 2 | **Alto** | Datos sensibles de asistencia de trabajadores; expuesto a manipulación de horarios. |
| **ACT-12** | Firewall UTM | Dispositivo Seguridad | Borde de Red (Gateway) | Unidad de Redes y Ciberseg. | 3 | 4 | 4 | **Crítico** | Filtrado perimetral, inspección y VPN institucional; si cae, colapsa el perímetro. |
| **ACT-13** | Entornos Dev Expuestos | Servidores Web / Staging | `dev.unap.edu.pe`, `prue1.*` | Desarrollo OTI | 3 | 2 | 1 | **Alto (R.)** | Aunque su valor operativo es bajo, representa vector vulnerable de entrada a la red. |
| **ACT-14** | Paneles Hosting cPanel | Consolas Web Hosting | `cpanel.portal.*`, `webdisk.*` | Admin. Web / Facultades | 4 | 4 | 2 | **Alto (R.)** | Consolas de gestión expuestas a Internet con riesgo de fuerza bruta y toma de control. |
| **ACT-15** | Repositorio DSpace | Gestor Documental | `repositorio.unap.edu.pe` | Vicerrectorado Investigación | 1 | 3 | 2 | **Medio** | Tesis y producción científica; públicos, pero su desfiguración afecta reputación. |
| **ACT-16** | Revistas Científicas | App Web (PHP) | `revistas.unap.edu.pe` | Vicerrectorado Investigación | 1 | 3 | 2 | **Medio** | Publicaciones indexadas; impacto directo en la reputación académica y licenciamiento. |
| **ACT-17** | Portal Institucional | CMS Web Informativo | `www.unap.edu.pe` | Oficina Comunicaciones / OTI | 1 | 3 | 3 | **Medio** | Rostro digital institucional; blanco habitual de Web Defacement o saturación DoS. |
| **ACT-18** | Portales de Facultades | Sitios Informativos | `derecho.unap.edu.pe`, etc. | Coordinadores Web Fac. | 1 | 2 | 1 | **Bajo** | Información de mallas curriculares; sin transacciones ni autenticación crítica. |
| **ACT-19** | Estaciones Admin. | Endpoints (Windows) | Oficinas Admin. (VLAN 30) | Jefaturas / Usuarios Finales | 3 | 3 | 2 | **Medio** | Vector común de entrada de malware (phishing/USB); almacena documentos locales. |
| **ACT-20** | Labs Cómputo Alumnos | Endpoints Compartidos | Pabellones Fac. (VLAN 40) | Responsables Lab / Decanatos | 1 | 2 | 2 | **Medio** | Equipos de alta rotación con riesgo de virus; deben aislarse de la red de servidores. |

## Sec 5.4 Conclusiones del Inventario de Activos y Brechas Identificadas

El análisis de criticidad e interdependencia de los 20 activos de la UNAP permite formular las siguientes conclusiones estratégicas de seguridad:

- **Sobreexposición de Activos Administrativos en Internet:** Se evidencia la exposición pública de subdominios correspondientes a consolas cPanel, webdisk y endpoints de desarrollo (`dev.*`, `dev2.*`, `prue1.*`). Bajo los lineamientos de Zero Trust, ninguno de estos servicios debe ser accesible directamente desde Internet, sino que deben confinarse a subredes de gestión accesibles únicamente mediante VPN corporativa con autenticación multifactor (MFA).
- **Concentración de Criticidad en el Dominio Académico:** Los activos **ACT-01** (Base de Datos), **ACT-02** (Matrícula) y **ACT-03** (Campus Virtual) concentran la mayor valoración de riesgo (Criticidad $= 4$). Un incidente en cualquiera de ellos bloquea las operaciones académicas de la universidad, lo que fundamenta priorizar el análisis de amenazas STRIDE y la implementación de controles en este segmento.
- **Dependencia de la Identidad Federada:** El correo institucional (**ACT-06**) actúa como la llave maestra de acceso a múltiples servicios. La ausencia de DMARC detectada en el dominio `unap.edu.pe` expone este activo a suplantaciones directas (*Spoofing*), amenazando la integridad del resto del inventario institucional.

# 6 ANÁLISIS DE AMENAZAS MEDIANTE STRIDE

En este capítulo se formaliza la descomposición funcional y el modelado preventivo de amenazas bajo el marco STRIDE sobre el sistema más crítico de la UNAP: la plataforma transaccional de matrícula académica.

## Sec 6.1 Metodología de Modelado STRIDE

La metodología STRIDE (desarrollada originalmente por Praerit Garg y Loren Kohnfelder en Microsoft) se fundamenta en la descomposición funcional de un sistema para responder de forma sistemática a cuatro interrogantes operativas:

1. **¿En qué estamos trabajando?** Construcción del Diagrama de Flujo de Datos (DFD).
2. **¿Qué puede salir mal?** Mapeo de categorías STRIDE sobre los elementos y límites de confianza.
3. **¿Qué vamos a hacer al respecto?** Definición de controles preventivos y correctivos.
4. **¿Hicimos un buen trabajo?** Evaluación residual del riesgo y verificación de controles.

El análisis modela las seis categorías de amenazas frente a las propiedades clásicas de seguridad de la información:

| Categoría STRIDE | Propiedad Violada | Definición en el Contexto del Software |
|---|---|---|
| **S — Spoofing** | **Autenticación** | Un actor malicioso finge ser un usuario legítimo (estudiante/docente) o suplanta un servicio del sistema. |
| **T — Tampering** | **Integridad** | Modificación malintencionada y no autorizada de datos en tránsito, en memoria o en reposo. |
| **R — Repudiation** | **No Repudio** | Un usuario realiza una acción transaccional y el sistema carece de evidencia inmutable para adjudicarle la autoría. |
| **I — Info Disclosure** | **Confidencialidad** | Exposición de credenciales, tokens, datos personales o metadatos de arquitectura a entidades no autorizadas. |
| **D — Denial of Service** | **Disponibilidad** | Saturación o degradación intencional de recursos (red, CPU, memoria, hilos web) para impedir el servicio legítimo. |
| **E — Elevation of Priv.** | **Autorización** | Un usuario con permisos limitados elude controles para ejecutar funciones de mayor privilegio administrativo. |

## Sec 6.2 Selección y Alcance del Sistema Objetivo

- **Sistema Evaluado:** Portal y API Transaccional de Matrícula (`https://matricula.unap.edu.pe`).
- **Capa de Borde:** Proxy inverso web `nginx/1.16.1` (Linux) encargado de la terminación TLS y enrutamiento perimetral.
- **Capa de Aplicación:** Servicio web compilado en ASP.NET Core (C#) ejecutándose sobre Kestrel/Linux, identificado mediante las cookies de sesión `.AspNetCore.Cookies` (fragmentadas en chunks) y el proveedor de estado temporal `.AspNetCore.Mvc.CookieTempDataProvider`.
- **Capa de Persistencia:** Motor de Base de Datos Académica Central (PostgreSQL / Oracle) alojado en el segmento privado del Data Center OTI.
- **Usuarios del Sistema:** Estudiantes de pregrado/posgrado (≈20,000 usuarios recurrentes), docentes y administradores de la Oficina de Tecnologías de la Información.

## Sec 6.3 Diagrama de Flujo de Datos (DFD) y Límites de Confianza

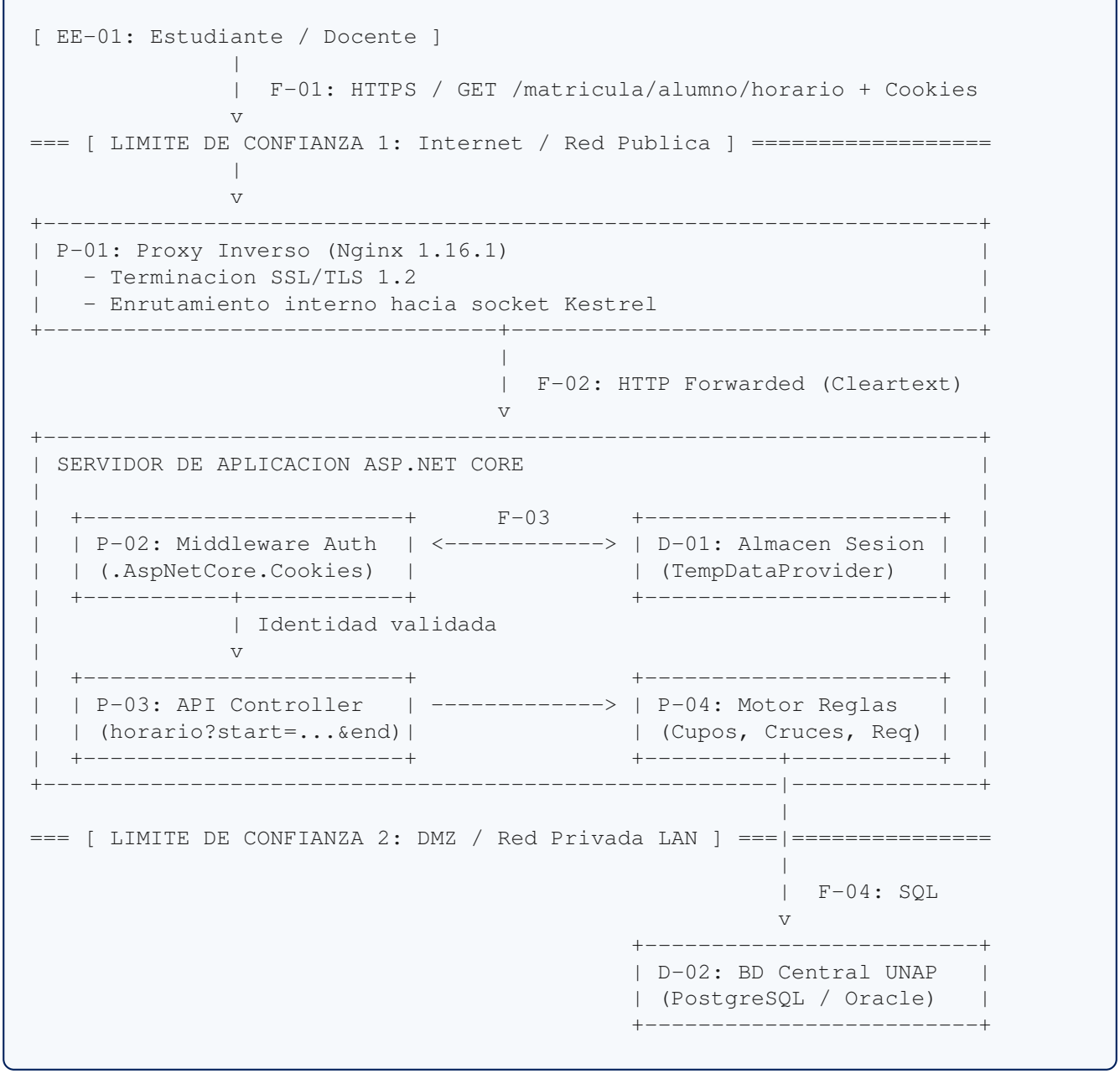
El modelado STRIDE exige delimitar claramente las fronteras de confianza (*Trust Boundaries*), que representan transiciones lógicas o físicas donde los privilegios cambian y el nivel de control disminuye.

### 6.3.1 Elementos del DFD Nivel 1

- **Entidades Externas (EE):** `EE-01`: Estudiante / Docente (Navegador Web / Cliente HTTP).
- **Procesos (P):**
  - `P-01`: Recepción, Terminación TLS y Reverse Proxy (Nginx 1.16.1).
  - `P-02`: Gestión de Sesión y Autenticación (Middleware ASP.NET Core Identity).
  - `P-03`: Consulta y Despliegue de Horario/Oferta (Endpoint `/matricula/alumno/horario`).
  - `P-04`: Lógica de Inscripción y Validación de Reglas (Cálculo de créditos, prerrequisitos y vacantes).
- **Almacenes de Datos (D):**
  - `D-01`: Almacén de Estado Temporal / Sesiones en Memoria (`CookieTempDataProvider`).
  - `D-02`: Base de Datos Académica Central (Tablas: Alumnos, Cursos, Actas, Cupos).
- **Flujos de Datos (F):**
  - `F-01`: Petición inicial HTTPS / Envío de credenciales o cookies (Cliente → Nginx).
  - `F-02`: Petición interna HTTP proxy-pass / Encabezados `X-Forwarded-*` (Nginx → ASP.NET Core).
  - `F-03`: Lectura/Escritura de estado de sesión (ASP.NET Core ↔ D-01).
  - `F-04`: Consultas transaccionales SQL / Stored Procedures (ASP.NET Core ↔ D-02).
  - `F-05`: Retorno de payload JSON con horario y estado HTTP 200 (ASP.NET Core → Nginx → Cliente).

### 6.3.2 Esquema Arquitectónico del DFD Nivel 1

**>_ | Arquitectura DFD Nivel 1 y Límites de Confianza (matricula.unap.edu.pe)**



## Sec 6.4 Evaluación de Riesgos (Criterio DREAD Adaptado)

Para cuantificar objetivamente la severidad de las amenazas identificadas en el sistema de matrícula, se aplica el modelo DREAD de Microsoft, evaluando cinco dimensiones con puntajes del 1 al 10:

$$\text{Riesgo Global} = \frac{\text{Damage} + \text{Reproducibility} + \text{Exploitability} + \text{Affected Users} + \text{Discoverability}}{5}$$

- **Damage (Daño potencial):** Perjuicio si el ataque tiene éxito (1 = Mínimo; 10 = Secuestro total de datos o parálisis institucional).
- **Reproducibility (Reproducibilidad):** Facilidad de replicar el ataque una vez descubierto (1 = Muy difícil o circunstancial; 10 = Funciona el 100 % de las veces).
- **Exploitability (Facilidad de explotación):** Destreza y herramientas requeridas (1 = Habilidades avanzadas de kernel/0-day; 10 = Petición HTTP simple con script público).
- **Affected Users (Usuarios afectados):** Proporción de la universidad impactada (1 = Un usuario individual; 10 = Toda la comunidad universitaria).
- **Discoverability (Descubribilidad):** Facilidad para hallar la debilidad (1 = Requiere código fuente; 10 = Visible en cabeceras HTTP públicas).

**Escala de Severidad Cualitativa: Bajo:** $1{,}0 - 4{,}9$ | **Medio:** $5{,}0 - 6{,}9$ | **Alto:** $7{,}0 - 8{,}9$ | **Crítico:** $9{,}0 - 10{,}0$.

## Sec 6.5 Matriz de Análisis STRIDE del Sistema de Matrícula (UNAP)

La siguiente matriz documenta las amenazas concretas detectadas a partir de las vulnerabilidades verificadas en el relevamiento perimetral:

| Cat. | Amenaza Identificada | Comp. | Vulnerabilidad Base | DREAD / Nivel | Controles de Mitigación Propuestos |
|---|---|---|---|---|---|
| **S** | Suplantación de Sesión: Robo de cookies `.AspNetCore.Cookies` e impersonación de identidad del alumno. | F-01, EE-01, P-02 | Sin binding de sesión a IP/huella TLS; sin revocación forzada tras logout. | **7.4** Alto (8,7,6,9,7) | 1. Revocación de tokens JWT / claims en Redis.<br>2. MFA obligatorio para docentes y condicional alumnos.<br>3. Binding de cookie a huella criptográfica de conexión. |
| **T** | Manipulación en Tránsito (SSL Stripping): Interceptación en texto plano de parámetros y cookies en Wi-Fi. | F-01, Límite 1 | Ausencia de HSTS (`Strict-Transport-Security`) en cabeceras web. | **8.0** Alto (8,8,7,8,9) | 1. Inyectar directiva HSTS estricta en Nginx (`max-age=31536000; preload`).<br>2. Redirección HTTP → HTTPS forzada (código 301). |
| **T** | Manipulación de Horario y Cruces: Peticiones alteradas en `horario?start` para forzar cupos colapsados. | P-03, P-04, F-04 | Validación de reglas en cliente sin doble chequeo atómico en backend. | **7.4** Alto (7,9,8,6,7) | 1. Validación transaccional atómica en backend y base de datos (nivel Serializable).<br>2. Verificación criptográfica de parámetros cliente. |
| **R** | Repudio de Matrícula: Estudiante alega que el sistema no registró su matrícula o notas sin refutación técnica. | P-02, D-02, F-04 | Logs web volátiles; solo registran código 200 sin User-ID ni hash transaccional. | **5.8** Medio (6,6,5,7,5) | 1. Bitácora transaccional inmutable (WORM) con User-ID, IP, timestamp NTP y hash del evento.<br>2. Envío centralizado a servidor Syslog / SIEM externo. |

| Cat. | Amenaza Identificada | Comp. | Vulnerabilidad Base | DREAD / Nivel | Controles de Mitigación Propuestos |
|---|---|---|---|---|---|
| **I** | Fuga de Versiones Obsoletas: Atacantes obtienen tecnología exacta para descargar exploits públicos. | P-01, Límite 1 | Cabecera expuesta: `Server: nginx/1.16.1` (versión 2019 con CVEs acumulados). | **8.8** Alto (7,10,8,9,10) | 1. Ocultar firma con `server_tokens off;` en Nginx.<br>2. Actualizar binario de Nginx a rama estable 1.26+.<br>3. Desplegar reglas de inspección perimetral WAF. |
| **I** | Fuga de Sesión Temporal: Interceptación de cookie `.AspNetCore.Mvc.CookieTempDataProvider`. | D-01, F-01 | Cookie temporal no incluye atributo `Secure` en directiva `Set-Cookie`. | **7.0** Alto (6,7,6,8,8) | 1. Endurecer política de cookies en `Program.cs`: `SecurePolicy = CookieSecurePolicy.Always; SameSite = SameSiteMode.Strict;`. |
| **D** | DoS por Agotamiento de Hilos: Colapso de proxy Nginx o cola Kestrel por concurrencia masiva en apertura. | P-01, P-03, D-02 | Sin limitación de tasa (*Rate Limiting*) por IP ni arquitectura elástica. | **9.0** Crítico (9,9,8,10,9) | 1. Configurar rate limiting en Nginx (`limit_req_zone`).<br>2. Balanceador de carga con instancias API redundantes.<br>3. Implementar sala de espera virtual (*Waiting Room*). |
| **E** | Elevación de Privilegios (IDOR): Modificación de IDs de usuario en URL para acceder a rutas de docentes. | P-03, P-04, F-04 | Control de acceso basado en URL sin verificación de claims de rol en backend. | **7.4** Alto (9,7,7,8,6) | 1. Autorización basada en políticas de claims (`[Authorize(Roles = "Docente,Admin")]`).<br>2. Validación de pertenencia obligatoria entre sesión y recurso. |

# Sec 6.6 Procedimiento de Implementación de Controles Mitigadores

Para transformar los hallazgos de la matriz STRIDE en salvaguardas operativas inmediatas dentro de la infraestructura de la UNAP, se establecen tres niveles de acción técnica:

## 6.6.1 A. Hardening Inmediato en Servidor Web Nginx (P-01)

Se debe modificar el bloque de configuración perimetral en el archivo institucional `/etc/nginx/sites-available/matricula.unap.edu.pe`:

**>_ | Configuración Nginx de Mitigación STRIDE – matricula.unap.edu.pe**

```
# Mitigacion STRIDE: Information Disclosure (Ocultamiento de version)
server_tokens off;

# Mitigacion STRIDE: Tampering y Spoofing (HSTS y proteccion de cabeceras)
add_header Strict-Transport-Security "max-age=31536000; includeSubDomains;
   preload" always;
add_header X-Frame-Options "SAMEORIGIN" always;
add_header X-Content-Type-Options "nosniff" always;
add_header Referrer-Policy "strict-origin-when-cross-origin" always;

# Mitigacion STRIDE: Denial of Service (Proteccion contra rafagas DoS)
limit_req_zone $binary_remote_addr zone=api_matricula:20m rate=15r/s;

server {
    listen 443 ssl http2;
    server_name matricula.unap.edu.pe;

    location / {
        limit_req zone=api_matricula burst=25 nodelay;
        proxy_pass http://127.0.0.1:5000; # Backend Kestrel ASP.NET Core
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
        proxy_set_header X-Forwarded-Proto $scheme;
    }
}
```

## 6.6.2 B. Aseguramiento del Manejo de Sesiones en ASP.NET Core (P-02 / D-01)

En el archivo de inicialización del backend (`Program.cs`), forzar el endurecimiento de las cookies transaccionales:

**>_ | Endurecimiento de Cookies y Autenticación en Program.cs**

```
builder.Services.Configure<CookiePolicyOptions>(options =>
{
    // Mitigacion STRIDE: Information Disclosure y Tampering en Cookies
    options.HttpOnly = Microsoft.AspNetCore.CookiePolicy.HttpOnlyPolicy.Always;
    options.Secure = Microsoft.AspNetCore.Http.CookieSecurePolicy.Always;
    options.MinimumSameSitePolicy = Microsoft.AspNetCore.Http.SameSiteMode.
   Strict;
});

builder.Services.AddAuthentication(CookieAuthenticationDefaults.
   AuthenticationScheme)
    .AddCookie(options =>
    {
        options.Cookie.Name = "__Host-UNAP-Auth"; // Cookie de prefijo seguro
        options.ExpireTimeSpan = TimeSpan.FromMinutes(20);
        options.SlidingExpiration = true;
    });
```

### 6.6.3 C. Control Transaccional en Base de Datos (P-04 / D-02)

Para mitigar la manipulación de prerrequisitos y vacantes (*Tampering* y *Elevation of Privilege*), toda inscripción debe ejecutarse dentro de un procedimiento almacenado transaccional que valide atómicamente el cupo con bloqueo pesimista:

**>_ | Función SQL Transaccional con Bloqueo FOR UPDATE contra Race Conditions**

```
-- Mitigacion STRIDE: Tampering (Bloqueo pesimista contra condiciones de
   carrera)
CREATE OR REPLACE FUNCTION sp_inscribir_asignatura(
    p_alumno_id INT,
    p_curso_id INT,
    p_grupo_id INT
) RETURNS BOOLEAN AS $$
DECLARE
    v_vacantes INT;
    v_inscritos INT;
BEGIN
    SELECT vacantes_totales INTO v_vacantes
    FROM oferta_academica
    WHERE grupo_id = p_grupo_id FOR UPDATE;

    SELECT COUNT(*) INTO v_inscritos
    FROM matricula_detalle
    WHERE grupo_id = p_grupo_id;

    IF v_inscritos < v_vacantes THEN
        INSERT INTO matricula_detalle(alumno_id, curso_id, grupo_id,
   fecha_registro)
        VALUES (p_alumno_id, p_curso_id, p_grupo_id, NOW());
        RETURN TRUE;
    ELSE
        RAISE EXCEPTION 'Cupo colapsado: no hay vacantes disponibles';
        RETURN FALSE;
    END IF;
END;
$$ LANGUAGE plpgsql;
```

# 7 INTELIGENCIA DE AMENAZAS (THREAT INTELLIGENCE)

En este capítulo se formaliza el programa de vigilancia activa, detección temprana y análisis continuo de ciberamenazas (Cyber Threat Intelligence - CTI), orientado a anticipar y neutralizar vectores de ataque contra el ecosistema tecnológico de la Universidad Nacional del Altiplano de Puno.

## Sec 7.1 Fundamentación y Objetivos de la Vigilancia Institucional

La Inteligencia de Amenazas (*Cyber Threat Intelligence* — CTI) en la Universidad Nacional del Altiplano de Puno no se concibe como una simple acumulación de listas de bloqueo, sino como un proceso analítico continuo destinado a transformar datos contextuales de adversarios en decisiones defensivas proactivas.

El propósito medular de CTI en la UNAP es anticipar los vectores de intrusión antes de que alcancen la fase de ejecución, mitigando los riesgos identificados en el relevamiento perimetral:

- **Suplantación de Identidad y Typosquatting:** Explotación de la reputación institucional para el despliegue de portales fraudulentos que clonan la interfaz de inicio de sesión de matrícula y campus virtual.
- **Explotación del Vector de Mensajería:** Aprovechamiento sistemático de la ausencia de registros DMARC (`NXDOMAIN`) y directivas permisivas SPF (`~all`) en el dominio `unap.edu.pe` para el envío de campañas de *Spear-Phishing* dirigidas contra autoridades, decanatos y docentes.
- **Ataques a Software Expuesto:** Campañas masivas de explotación orientadas a versiones legadas de servidores web (como la rama `nginx/1.16.1` detectada) y vulnerabilidades en gestores de contenido web institucionales.
- **Fuga de Credenciales:** Detección de cuentas `@unap.edu.pe` expuestas en filtraciones masivas (*stealer logs* o *data dumps* en la Dark Web).

## Sec 7.2 Ciclo Operativo de Threat Intelligence en la UNAP

El flujo operativo se modela a través de un ciclo continuo de seis fases adaptado al ámbito universitario:




Figura 7.1: Ciclo Continuo de Threat Intelligence adaptado a la UNAP.

- **Dirección y Planeación:** El Oficial de Seguridad (CISO) y la Jefatura de OTI definen las prioridades de vigilancia de acuerdo con el calendario académico (épocas críticas: convocatorias de admisión, matrículas semestrales, elecciones y subida de actas de notas).
- **Recolección de Información:** Ingesta de fuentes especializadas y telemetría institucional:
  - *Fuentes Abiertas y Plataformas CTI (OSINT):* AlienVault OTX, AbuseIPDB, VirusTotal, Shodan, crt.sh (monitoreo de nuevos certificados emitidos para `*.unap.edu.pe`).
  - *Fuentes Estatales y Sectoriales:* Alertas del Centro Nacional de Seguridad Digital (CSIRT Nacional de la PCM/SGTD) y RENATA/RedCLARA para redes académicas.
  - *Telemetría Interna:* Logs de accesos HTTP de Nginx, registros de autenticación de Google Workspace / M365 y eventos del firewall perimetral.
- **Procesamiento y Normalización:** Extracción y depuración de Indicadores de Compromiso (IoCs) categorizados bajo el estándar estructurado STIX/TAXII (direcciones IP, dominios apócrifos, hashes SHA-256 de ejecutables/documentos maliciosos y patrones URI).
- **Análisis y Correlación:** Cruce de los IoCs extraídos contra las bases de datos de accesos de la UNAP. Si una IP maliciosa con reporte internacional de fuerza bruta ha consultado el endpoint `/matricula/alumno/horario`, se califica como incidente potencial en curso.
- **Difusión:** Emisión de boletines técnicos dirigidos al equipo de infraestructura para el bloqueo inmediato, y comunicados preventivos hacia la comunidad universitaria si el vector apunta a ingeniería social.
- **Retroalimentación y Acción Defensiva:** Inyección automática/manual de reglas en el Firewall UTM (bloqueo de IPs), en el servidor proxy Nginx (denegación de User-Agents maliciosos) y en la pasarela de correo electrónico.

## Sec 7.3 Taxonomía de Indicadores de Compromiso (Pirámide del Dolor)

Para enfocar los esfuerzos del equipo de seguridad donde generen mayor impacto defensivo, la UNAP clasifica los hallazgos de Threat Intelligence según la Pirámide del Dolor de David Bianco:

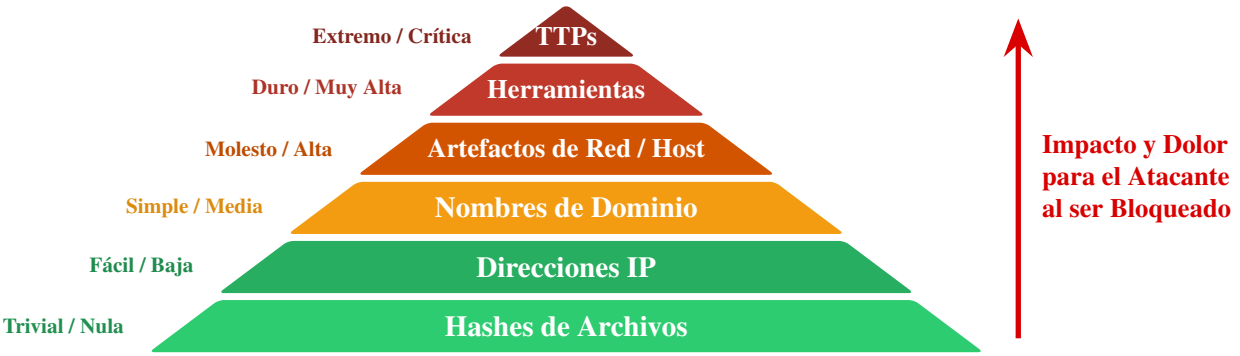



Figura 7.2: Pirámide del Dolor de David Bianco aplicada a la clasificación de IoCs en la UNAP.

| Nivel | Tipo de Indicador | Dificultad Atacante | Aplicación Defensiva en la UNAP |
|---|---|---|---|
| **Trivial** | Hashes de archivos (MD5, SHA-256) | Nula (cambia 1 bit y el hash varía). | Bloqueo en estaciones de trabajo y laboratorios vía EDR/Antivirus institucional. |
| **Fácil** | Direcciones IP | Baja (el atacante rota proxies y VPNs). | Listas negras dinámicas en el Firewall perimetral y WAF de la universidad. |
| **Simple** | Nombres de Dominio | Media (requiere comprar y registrar otro). | Bloqueo a nivel de servidores DNS locales (DNS Sinkhole) y monitoreo WHOIS/crt.sh. |
| **Molesto** | Artefactos de Red / Host | Alta (requiere reescribir herramientas). | Detección de patrones específicos en cabeceras HTTP o nombres de tareas programadas. |
| **Duro** | Herramientas | Muy Alta (debe reprogramar o buscar nuevo software). | Reglas YARA y firmas de comportamiento contra herramientas automatizadas (Hydra, Sqlmap). |
| **Extremo** | TTPs (Tácticas, Técnicas y Procedimientos) | Crítica (obliga al atacante a cambiar su modo de operar). | Mapeo MITRE ATT&CK: Mitigar spearphishing exigiendo MFA obligatorio e implementando HSTS. |

## Sec 7.4 Producto Operativo: Boletín de Inteligencia de Amenazas

A continuación se presenta el modelo oficial de boletín técnico generado para documentar una amenaza real y activa detectada durante el relevamiento de la superficie institucional:

**>_ | Boletín Oficial de Inteligencia de Amenazas - CSIRT-UNAP / OTI**

```
==========================================================================
       OFICINA DE TECNOLOGIAS DE LA INFORMACION - UNAP
            UNIDAD DE REDES Y CIBERSEGURIDAD (SOC-UNAP)
==========================================================================
BOLETIN DE INTELIGENCIA DE AMENAZAS | REF: CTI-UNAP-2026-003
FECHA DE EMISION: 17 de Octubre de 2026
NIVEL DE SEVERIDAD: ALTO (AMBAR)
TLP: AMBER (Uso exclusivo interno OTI / Administradores de Red y Sistemas)
==========================================================================

1. TITULO:
Campana de Spear-Phishing y Explotacion Perimetral orientada a
credenciales academicas aprovechando ausencia de directiva DMARC.

2. RESUMEN EJECUTIVO:
El equipo de seguridad ha detectado el registro y circulacion de
vectores de suplantacion dirigidos a la comunidad universitaria de la
UNAP. La amenaza combina el envio de correos fraudulentos con remitente
falseado (@unap.edu.pe) -posibilitado por la inexistencia de registros
DMARC en la zona DNS institucional- con portales de phishing que clonan
el inicio de sesion de matricula, buscando capturar credenciales de
acceso (.AspNetCore.Cookies) y datos personales.

3. ANALISIS DE LA AMENAZA Y VECTORES TECNICOS:
A. Vector de Entrega (Email Spoofing):
   - Aprovechamiento del registro SPF actual: "v=spf1 ... ~all" (SoftFail).
   - Ausencia total del host "_dmarc.unap.edu.pe" (NXDOMAIN verificado).
   - Servidores de correo externos entregan los mensajes a las bandejas
     de docentes y alumnos al no existir directivas de rechazo (p=reject).

B. Vector de Explotacion Web (Infraestructura Clonada):
   - Despliegue de un dominio apocrifo: "matricula-unap-edu[.]pe".
   - Certificado SSL gratuito emitido para dar apariencia de legitimidad.
   - Formulario que captura usuario y contrasena, y retransmite al
     backend legitimo para evitar sospechas inmediatas del usuario.

4. INDICADORES DE COMPROMISO (IoCs):
   A. Indicadores de Red (Dominios y URLs Maliciosas):
      - Dominio: matricula-unap-edu[.]pe
      - Dominio: unap-soporte-academico[.]com
      - URL Phishing: hxxps://matricula-unap-edu[.]pe/login/alumno
      - URL Payload:  hxxps://unap-soporte-academico[.]com/assets/auth_sync.js

   B. Direcciones IP de Servidores C2 / Phishing:
      - 185.220.101.45 (Trafico scanning hacia /matricula/alumno/*)
      - 194.26.29.112  (Servidor hosting del portal falso)
      - 45.154.255.89  (Nodo Tor con fuerza bruta sobre Nginx 1.16.1)
```

```
   C. Hashes Criptograficos de Adjuntos Simulados (SHA-256):
      - 8f4b1e5a2c3d0b9a8f7e6d5c4b3a2f1e0d9c8b7a6f5e4d3c2b1a0f9e8d7c6b5a
        (Falso archivo: "Cronograma_Rectificacion_Matricula_2026.pdf.exe")

   D. Asuntos de Correo Utilizados en la Campana:
      - "[URGENTE] Regularizacion obligatoria de matricula 2026"
      - "Actualizacion de seguridad requerida en su cuenta UNAP"

5. MAPEO CON METODOLOGIAS Y MARCOS DE SEGURIDAD:
   - STRIDE: Spoofing (S), Tampering (T), Information Disclosure (I).
   - MITRE ATT&CK:
     * T1566.002 (Phishing: Spearphishing Link)
     * T1589.002 (Gather Victim Identity Info: Email Addresses)
     * T1078.003 (Valid Accounts: Local Accounts)
   - Cyber Kill Chain:
     * Fase 1 (Reconocimiento) -> Fase 3 (Entrega) -> Fase 4 (Explotacion).
6. ACCIONES DEFENSIVAS INMEDIATAS APLICADAS:
   [X] Bloqueo de direcciones IP atacantes en Firewall FortiGate.
   [X] Inyeccion en servidores DNS resolver para redirigir dominios
       maliciosos a IP de Loopback (127.0.0.1 - Sinkhole).
   [X] Regla de cuarentena estricta en panel de correo para mensajes
       cuyo encabezado contenga "matricula-unap".
7. MEDIDAS ESTRUCTURALES MANDATORIAS (PROPUESTA ZERO TRUST):
   1. Gestion de DNS Institucional:
      Publicar inmediatamente el registro TXT en "_dmarc.unap.edu.pe":
      "v=DMARC1; p=quarantine; sp=quarantine; rua=mailto:seguridad@unap.edu.pe;
    pct=100"
      para forzar a los servidores receptores a enviar a cuarentena.
   2. Modificacion de SPF:
      Cambiar la directiva final de "~all" (SoftFail) a "-all" (HardFail).
   3. Despliegue de MFA:
      Exigir autenticacion multifactor (MFA) en todas las cuentas docentes
      y administrativas para neutralizar credenciales robadas.
================================================================================
```

## Sec 7.5 Procedimiento de Actualización y Gobernanza

Para garantizar la sostenibilidad y eficacia operativa de la inteligencia de amenazas en la UNAP, se establecen los siguientes lineamientos de gobernanza:

- **Frecuencia de Emisión:** El SOC-UNAP emitirá boletines de inteligencia bajo demanda (ante incidentes críticos de severidad Alta/Crítica) y un reporte de resumen quincenal con métricas de IoCs mitigados.
- **Repositorio Central de Indicadores:** Los IoCs se consolidarán en una plataforma de gestión de amenazas de código abierto (como MISP — *Malware Information Sharing Platform*) alojada localmente en la DMZ de la OTI, permitiendo la sincronización de listas con el firewall perimetral y el SIEM Wazuh.
- **Canal de Notificación a la Comunidad:** Ante campañas activas de ingeniería social, se emitirá una versión desclasificada y simplificada en formato infográfico a través de los canales institucionales oficiales (`prensa.unap.edu.pe`, redes sociales y banner informativo en el portal de matrícula).

# 8 ANÁLISIS MEDIANTE MITRE ATT&CK

## Sec 8.1 Fundamentación y Marco Teórico de MITRE ATT&CK

El marco MITRE ATT&CK (*Adversarial Tactics, Techniques, and Common Knowledge*) es una base de conocimiento global y estandarizada que clasifica el comportamiento táctico y técnico de actores maliciosos basándose en observaciones directas del mundo real.

A diferencia de modelos estrictamente lineales (como la *Cyber Kill Chain*), MITRE ATT&CK opera como una matriz multidimensional no secuencial. Su estructura permite comprender no solo qué fase atraviesa una intrusión, sino cómo actúa técnicamente el adversario en cada etapa mediante tres niveles jerárquicos:

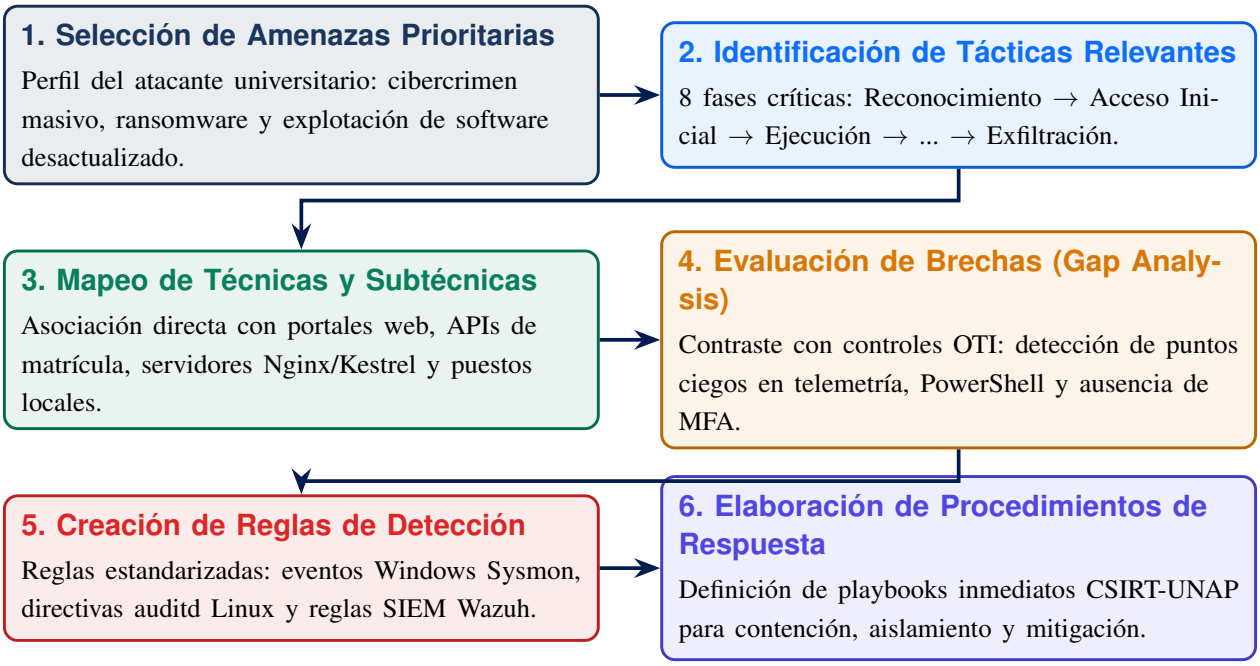
- **Tácticas (El Objetivo):** Representan el "por qué" de una acción; la meta operativa intermedia que persigue el atacante (ej. Acceso Inicial, Persistencia, Movimiento Lateral).
- **Técnicas (El Método):** Representan el "cómo"; el método tecnológico o procedimental concreto empleado para alcanzar la táctica (ej. *Spearphishing Link*, *Valid Accounts*, *Web Shell*).
- **Subtécnicas y Procedimientos:** La implementación específica y detallada documentada en el comportamiento de grupos de ciberamenazas conocidos (APTs) o variantes de malware.

En el contexto de la Universidad Nacional del Altiplano de Puno (UNAP), la matriz MITRE ATT&CK Enterprise v14 se utiliza como el estándar técnico para:

1. **Evaluación de cobertura:** Evaluar de forma sistemática la cobertura defensiva frente al perfil de intrusión universitario.
2. **Mapeo de debilidades:** Mapear las debilidades de configuración detectadas en el relevamiento perimetral (`Server: nginx/1.16.1`, falta de directiva HSTS, cookies de sesión ASP.NET Core y ausencia de registros DMARC).
3. **Telemetría y detección:** Definir reglas de telemetría y monitoreo (SIEM/EDR) basadas en registros reales de auditoría.

## Sec 8.2 Procedimiento de Análisis y Evaluación de Brechas

Para operacionalizar MITRE ATT&CK dentro del Plan de Ciberseguridad de la UNAP, se implementa un procedimiento estructurado de seis etapas:




A continuación, se detalla el contenido operativo de cada fase del procedimiento:

1. **Selección de Amenazas Prioritarias:** Se define el perfil del adversario que ataca al sector educación superior peruano: actores motivados por robo masivo de identidades/credenciales, grupos de *ransomware* que extorsionan con la paralización de sistemas de matrícula o planillas, y atacantes oportunistas que explotan software público desactualizado.

2. **Identificación de Tácticas Relevantes:** Se seleccionan las 8 fases críticas de intrusión: Reconocimiento → Acceso Inicial → Ejecución → Persistencia → Escalada de Privilegios → Descubrimiento → Movimiento Lateral → Exfiltración.

3. **Mapeo de Técnicas Específicas:** Se asocian técnicas de la matriz ATT&CK a los componentes descubiertos en la UNAP (portales web, APIs de matrícula, servidores Nginx/Kestrel, controladores de dominio y puestos de trabajo).

4. **Evaluación de Brechas de Cobertura (*Gap Analysis*):** Se contrasta la capacidad de detección actual de la OTI frente a cada técnica, identificando puntos ciegos (por ejemplo: falta de inspección en terminales PowerShell, logs web que no se correlacionan o ausencia de alertas por uso anómalo de credenciales válidas).

5. **Creación de Reglas de Detección:** Se diseñan reglas específicas en formato de eventos de Windows (Sysmon/Event ID), directivas de inspección para Linux auditd y firmas de correlación en el SIEM institucional (Wazuh).

6. **Definición de Respuestas:** Se establecen acciones inmediatas para mitigar o interrumpir cada técnica cuando sea alertada por el centro de operaciones de seguridad.

## Sec 8.3 Matriz Institucional MITRE ATT&CK (UNAP)

La siguiente tabla articula el mapeo completo de técnicas aplicadas a la infraestructura real evaluada, contrastando los controles existentes, las brechas identificadas y la regla técnica de detección:

| Fase / Táctica | ID Técnica | Nombre de Técnica | Comportamiento del Adversario en la UNAP | Controles Existentes / Brecha Identificada | Mecanismo de Detección y Regla SIEM |
|---|---|---|---|---|---|
| **Reconocimiento** | T1596.001 | Search Open Technical Databases: DNS/ Certificates | Consulta masiva de certificados SSL en `crt.sh` y registros DNS para mapear subdominios internos (`dev`, `prue1`, `cpanel.*`). | **Brecha:** Actividad 100 % pasiva; indetectable en el firewall perimetral por ejecutarse sobre servidores públicos de terceros. | Monitoreo externo mensual de Certificate Transparency Logs mediante scripts automatizados en la OTI. |
| **Reconocimiento** | T1589.002 | Gather Victim Identity Info: Email Addresses | Búsqueda y recolección de correos de docentes y autoridades en directorios públicos y resoluciones de `unap.edu.pe`. | **Brecha:** Nombres y correos expuestos sin mecanismos de ofuscación ni CAPTCHA en portales de facultades. | Implementación de Cloudflare / WAF perimetral para detectar *scraping* agresivo y recolección masiva de HTML. |
| **Acceso Inicial** | T1566.002 | Phishing: Spearphishing Link | Envío de correos simulando ser la OTI con enlaces a sitios clonados para robar accesos al sistema de matrícula. | **Brecha Crítica:** Inexistencia de registro DMARC (`NXDOMAIN`) y política permisiva `SPF: ãll` en `unap.edu.pe`. | Detección de correos entrantes con remitente simulado; activación de alertas por fallos de alineación SPF/DKIM en pasarela de correo. |
| **Acceso Inicial** | T1078.003 | Valid Accounts: Local Accounts | Autenticación ilegítima en la API de matrícula o VPN utilizando credenciales legítimas comprometidas de estudian-tes/docentes. | **Brecha:** Falta de autenticación multifactor (MFA) obligatoria y nula correlación geográfica de inicios de sesión. | **Regla SIEM (Wazuh):** Alerta por inicios de sesión simultáneos imposibles (dos IPs con más de 300 km de distancia en un intervalo menor a 15 minutos). |
| **Ejecución** | T1059.001 | Command and Scripting Interpreter: PowerShell | Ejecución de scripts *encoded* descargados mediante macros o ejecutables fraudulentos en computadoras administrativas. | **Brecha:** Antivirus tradicional sin capacidad de inspección de línea de comandos en puestos de tesorería y decanatos. | **Sysmon Event ID 1 / PowerShell Event ID 4104:** Alerta por ejecución de `powershell.exe` con argumentos `-EncodedCommand`, `-WindowStyle Hidden` o `DownloadString`. |

| Fase / Táctica | ID Técnica | Nombre de Técnica | Comportamiento del Adversario en la UNAP | Controles Existentes / Brecha Identificada | Mecanismo de Detección y Regla SIEM |
|---|---|---|---|---|---|
| **Persistencia** | T1505.003 | Server Software Component: Web Shell | Subida de archivos ejecutables camuflados (.php, .aspx) en carpetas públicas de subida de fotos de admisión o campus virtual. | **Brecha:** Servidores web sin bloqueo de ejecución de código en directorios /uploads/ o /assets/. | **Monitoreo de Integridad (FIM - Wazuh):** Alerta instantánea ante la creación o modificación de archivos con extensiones ejecutables en rutas web públicas. |
| **Escalada Priv.** | T1068 | Exploitation for Privilege Escalation | Explotación de vulnerabilidades de kernel local o configuraciones defectuosas en el proxy Linux Nginx desactualizado. | **Brecha:** Presencia de Server: nginx/1.16.1 (rama del 2019 con vulnerabilidades conocidas y parches desactualizados). | Inspección de llamadas al sistema con auditd en Linux; detección de ejecuciones sospechosas con privilegios root invocadas desde nginx o www-data. |
| **Descubrimiento** | T1046 | Network Service Discovery | Barrido de puertos internos (TCP 5432 / 1433 / 445) desde una PC infectada en laboratorios de cómputo para ubicar la base de datos central. | **Brecha:** Red universitaria plana en ciertas facultades, sin aislamiento estricto de puertos cliente a cliente. | **Detección IDS (Suricata / Snort):** Alerta por ráfagas de paquetes TCP SYN dirigidas a más de 20 puertos distintos en menos de 5 segundos desde una misma IP local. |
| **Movimiento Lateral** | T1021.002 | Remote Services: SMB/Windows Admin Shares | Propagación hacia servidores o PCs contables mediante el protocolo SMB (puerto 445) reutilizando credenciales administrativas. | **Brecha:** Uso de contraseñas de administrador local idénticas en equipos de trabajo administrativos. | **Windows Event ID 4624 (Logon Type 3):** Bloqueo de tráfico SMB entre estaciones mediante firewall de host; alerta de conexiones remotas entre IPs de usuarios. |
| **Exfiltración** | T1048.003 | Exfiltration Over Unencrypted / Encrypted Non-C2 Protocol | Envío masivo de volcados de bases de datos de notas, padrones de estudiantes o datos biométricos hacia servidores externos. | **Brecha:** Tráfico saliente de subida sin inspección de volumen ni controles DLP (*Data Loss Prevention*). | **NetFlow / Zeek:** Alerta de umbral por transferencias salientes continuas que superen los 100 MB desde el segmento de servidores hacia IPs públicas no institucionales. |

## Sec 8.4 Especificación de Reglas de Detección e Implementación

Para asegurar que el plan proporcione herramientas técnicas directamente aplicables en la OTI, se definen tres reglas de detección estandarizadas listas para ser integradas en el entorno defensivo:

### Regla 1: Detección de Web Shells en Servidores Web UNAP (Wazuh FIM / Sysmon)

Apunta a neutralizar la técnica T1505.003 en directorios de aplicaciones web (`matricula`, `campus`, `admision`):

**>_ | Regla Wazuh FIM: Deteccion Web Shell (T1505.003)**

```
<!-- Regla Wazuh / Ossec para detectar persistencia en servidores web -->
<group name="syscheck,web_attack,">
  <rule id="100100" level="12">
    <if_sid>550</if_sid>
    <field name="file">/var/www/|/usr/share/nginx/html/|C:\inetpub\wwwroot\</
   field>
    <match regex="(?i)\.(php|aspx|asp|jsp|sh|py)$">file</match>
    <description>ALERTA CRITICA: Creacion o modificacion de archivo ejecutable
   en directorio web publico (Posible Web Shell - T1505.003)</description>
    <mitre>
      <id>T1505.003</id>
    </mitre>
  </rule>
</group>
```

### Regla 2: Detección de Ejecución de Comandos Ocultos (PowerShell T1059.001)

Diseñada para estaciones de trabajo administrativas donde los atacantes intentan ejecutar cargas maliciosas recibidas por correo:

**>_ | Sysmon Event ID 1: Proceso Sospechoso (T1059.001)**

```
<!-- Deteccion Sysmon Event ID 1: Proceso sospechoso en estaciones UNAP -->
<RuleGroup name="detect_powershell_hidden" groupRelation="or">
  <ProcessCreate onmatch="include">
    <Rule groupRelation="and">
      <Image condition="end with">powershell.exe</Image>
      <CommandLine condition="contains any">-enc;-encodedcommand;-w hidden;-
   windowstyle hidden;downloadstring;bypass</CommandLine>
    </Rule>
  </ProcessCreate>
</RuleGroup>
```

### Regla 3: Detección de Anomalías de Concurrencia y Fuerza Bruta en Nginx (T1110 / T1078)

Configurada sobre los logs de acceso de `/var/log/nginx/access.log` para mitigar ataques dirigidos contra el endpoint `/matricula/alumno/horario` o la interfaz de login:

**>_ | Regla Sigma: Deteccion Fuerza Bruta en Nginx**

```
# Regla de deteccion en SIEM / Sigma Rule
title: Intentos Masivos de Fuerza Bruta / Credential Stuffing en Portal UNAP
status: experimental
description: Detecta mas de 15 respuestas HTTP 401 o 403 en menos de 1 minuto
    desde una misma IP contra los endpoints de autenticacion.
logsource:
  service: nginx_access
detection:
  selection:
    uri|contains:
      - '/matricula/login'
      - '/auth/login'
      - '/campus/login'
    status:
      - 401
      - 403
  timeframe: 1m
  condition: selection | count() > 15
tags:
  - attack.credential_access
  - attack.t1110.001
level: high
```

## Sec 8.5 Acciones de Respuesta y Remediación por Táctica

Para cerrar el ciclo operativo, el equipo de respuesta a incidentes (CSIRT-UNAP) ejecutará los siguientes procedimientos operativos estándar ante la activación de alertas mapeadas en ATT&CK:

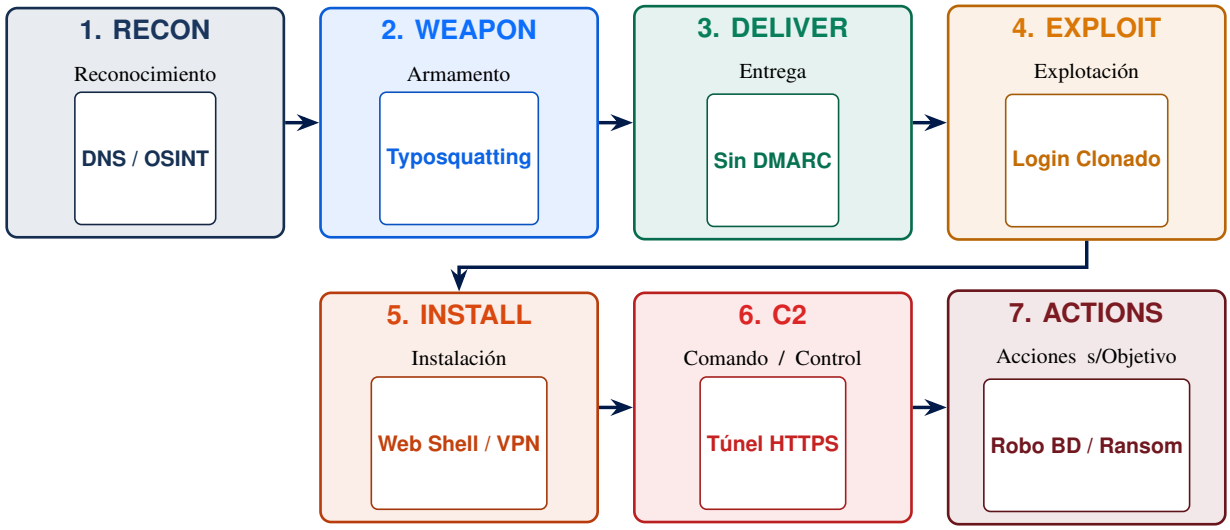
- **Ante alertas de Reconocimiento / Acceso Inicial (T1566 / T1078):**
  - Revocación inmediata de tokens de sesión activos (`.AspNetCore.Cookies`) y forzado de reseteo de credenciales en el directorio unificado.
  - Aislamiento preventivo de la IP de origen en las tablas dinámicas del Firewall perimetral (*Drop rules* por 72 horas).
- **Ante alertas de Ejecución / Persistencia (T1059 / T1505):**
  - Aislamiento lógico de la estación o servidor web mediante corte de red en switch/VLAN (manteniendo la alimentación eléctrica para análisis forense de memoria volátil).
  - Extracción de artefactos, eliminación de archivos no autorizados y restauración del contenedor/servicio web a partir de la imagen dorada (*Golden Image*) del repositorio Git institucional.
- **Ante alertas de Descubrimiento / Movimiento Lateral (T1046 / T1021):**
  - Deshabilitación temporal de cuentas de servicio o usuarios locales de administración compartidos.
  - Verificación y bloqueo de tráfico este-oeste entre subredes de facultades y el segmento del Data Center de la OTI.

# 9 ANÁLISIS MEDIANTE CYBER KILL CHAIN

## Sec 9.1 Fundamentación del Modelo Cyber Kill Chain

El modelo *Cyber Kill Chain*, desarrollado por Lockheed Martin en el marco del concepto de Intrusión Basada en Inteligencia, desglosa una amenaza avanzada y dirigida en una secuencia lineal y multifásica de siete etapas interdependientes.

El principio operacional medular de este modelo radica en la **asimetría defensiva**: mientras que un ciberadversario requiere superar con éxito el 100 % de las fases consecutivas para lograr su meta final, el equipo defensivo de la universidad solo necesita quebrar de manera efectiva uno de los eslabones para neutralizar el ataque por completo, minimizando los costos de remediación e impidiendo el impacto sobre los activos críticos institucionales.




En el presente plan, la *Cyber Kill Chain* se aplica para modelar un escenario de amenaza verosímil y de alto impacto contra la UNAP: el despliegue de una campaña orquestada de *Spear-Phishing* masivo y robo de credenciales en vísperas del proceso de matrícula y rectificaciones, aprovechando de forma directa las debilidades reales verificadas en la zona DNS y configuración perimetral de la institución.

# Sec 9.2 Análisis Fase por Fase: Escenario de Intrusión Dirigida en la UNAP

## Fase 1: Reconocimiento (*Reconnaissance*)

- **Objetivo del Adversario:** Recolección de información sobre la arquitectura tecnológica, nombres de dominio, sistemas expuestos y estructura organizativa de la UNAP sin interactuar de forma intrusiva con la red interna.
- **Acciones del Atacante sustentadas en Evidencias:**
  - Consulta pasiva de registros de Transparencia de Certificados SSL (`crt.sh/?q=%25.unap.edu.pe`), identificando más de 100 subdominios, entre ellos los portales centrales (`matricula.unap.edu.pe`, `campus.unap.edu.pe`), APIs de gestión (`api.unap.edu.pe`, `apibiometrico.unap.edu.pe`) y servidores de desarrollo expuestos (`dev.unap.edu.pe`, `prue1.unap.edu.pe`).
  - Análisis de respuestas HTTP en `matricula.unap.edu.pe`, descubriendo la versión exacta del servidor web perimetral mediante la cabecera `Server: nginx/1.16.1` y la presencia de cookies `.AspNetCore.Cookies`, revelando el stack tecnológico ASP.NET Core sobre Linux.
  - Extracción en fuentes abiertas (portal institucional, redes sociales, resoluciones rectorales) de la estructura de autoridades, decanos, directores de escuela y listas de correos institucionales de docentes (`@unap.edu.pe`).
- **Vulnerabilidad Explotada:** Exposición de banners informativos del servidor (`server_tokens` activo) y metadatos públicos en subdominios no inventariados.

## Fase 2: Armamento (*Weaponization*)

- **Objetivo del Adversario:** Creación del artefacto malicioso y preparación de la infraestructura tecnológica apócrifa emparejando un vector de engaño con el software objetivo.
- **Acciones del Atacante:**
  - Registro de un dominio tipográfico fraudulento (*typosquatting*) diseñado para inducir a error visual, tal como `matricula-unap-edu[.]pe` o `unap-tramite-academico[.]com`.
  - Emisión de un certificado SSL/TLS gratuito (Let's Encrypt o ZeroSSL) para desplegar el candado de seguridad en la barra de direcciones del navegador.
  - Clonación pixel por pixel de la interfaz gráfica del portal oficial de autenticación de matrícula de la UNAP, integrando un script en backend (PHP/Node.js) configurado para interceptar y almacenar las credenciales ingresadas (DNI, contraseña y códigos de verificación).

- Redacción de una plantilla de correo electrónico persuasiva suplantando a la Oficina de Tecnologías de la Información (OTI):

  *"Estimado(a) docente/estudiante: Por disposición del Vicerrectorado Académico y en el marco del inicio del ciclo de matrícula, es mandatorio validar sus credenciales institucionales antes de las 23:59 hrs para evitar la inhabilitación del acceso al sistema. Ingrese al siguiente enlace:* `https://matricula-unap-edu[.]pe/login`*".*



## Fase 3: Entrega (*Delivery*)

- **Objetivo del Adversario:** Transmitir el señuelo y enlace fraudulento a las bandejas de entrada del personal docente, directores de escuela y alumnos de la UNAP.
- **Acciones del Atacante sustentadas en Evidencias de DNS:**
  - El atacante configura su propio servidor de correo saliente (Postfix / SendGrid) para inyectar correos falsificando el encabezado de remitente `From: soporte.oti@unap.edu.pe`.
  - **Explotación de la Brecha DNS Real 1 (SPF Permisivo):** La consulta DNS sobre el dominio arrojó:

    ```
    "v=spf1 ip4:208.70.245.162 a:sfulib10.nmsrv.com
            include:_spf.google.com ãll"
    ```

    El modificador `ãll` (*SoftFail*) no instruye a los servidores de correo receptores a descartar el mensaje, sino únicamente a catalogarlo como sospechoso o enviarlo con baja puntuación de spam.
  - **Explotación de la Brecha DNS Real 2 (Ausencia Total de DMARC):** La consulta DNS sobre `_dmarc.unap.edu.pe` devolvió *Non-existent domain* (`NXDOMAIN`). Al no existir una política DMARC publicada por la universidad, los servidores de correo (Google Workspace, Microsoft 365, servidores corporativos) no reciben directivas institucionales que ordenen el rechazo (`p=reject`) o la cuarentena (`p=quarantine`) de correos falsificados en nombre de `unap.edu.pe`.
- **Resultado:** El correo de phishing supera los filtros perimetrales y es depositado directamente en la bandeja de entrada de cientos de docentes y administrativos de la UNAP sin advertencias explícitas de suplantación de dominio.



## Fase 4: Explotación (*Exploitation*)

- **Objetivo del Adversario:** Materializar el engaño y lograr que la víctima ejecute la acción prevista.
- **Acciones del Atacante:**
  - El docente o administrativo hace clic sobre el enlace del correo fraudulento.

- **Explotación de la Brecha Web Real (Ausencia de HSTS):** Al estar desactivada la directiva `Strict-Transport-Security` en los portales universitarios (`campus.unap.edu.pe` y `matricula.unap.edu.pe`), los usuarios están habituados a transitar entre enlaces HTTP y HTTPS sin que el navegador bloquee o alerte sobre discrepancias en certificados estrictos o redirecciones en texto plano.
- La víctima introduce su identificador de usuario y contraseña institucional en el portal clonado.
- El script del atacante captura en tiempo real las credenciales y redirige inmediatamente al usuario a la página legítima de la UNAP (`matricula.unap.edu.pe/informacion`), provocando la impresión de un fallo temporal de conexión y evitando que la víctima sospeche del robo.



## Fase 5: Instalación (*Installation*)

- **Objetivo del Adversario:** Establecer un punto de apoyo persistente en la infraestructura institucional utilizando el vector obtenido.
- **Acciones del Atacante:**
  - Con las credenciales comprometidas de un docente o administrador de la OTI, el atacante inicia sesión en la intranet o en el servicio de VPN institucional de la UNAP.
  - **Brecha Explotada: Ausencia de Autenticación Multifactor (MFA) obligatoria.** Dado que la autenticación depende exclusivamente de la contraseña estática, el atacante obtiene acceso inmediato sin requerir un segundo factor en un dispositivo físico.
  - Aprovechando los permisos de la cuenta docente comprometida en la plataforma de Campus Virtual / Moodle o en el sistema de admisiones, el atacante localiza formularios de carga de archivos (ej. subida de sílabos, fotos de postulantes o tareas) y elude la validación de extensiones para subir una Web Shell PHP/ASPX ofuscada en una ruta accesible (`/uploads/2026/shell.php`).



## Fase 6: Comando y Control - C2 (*Command and Control*)

- **Objetivo del Adversario:** Abrir un canal de comunicación seguro y bidireccional entre el servidor comprometido de la UNAP y la infraestructura remota del atacante para emitir órdenes.
- **Acciones del Atacante:**
  - La Web Shell o un payload ligero descargado invoca una conexión reversa (*Reverse Shell*) vía HTTPS saliente (puerto TCP 443) hacia la dirección IP del servidor C2 (`194.26.29.112`).
  - **Brecha Explotada: Salida a Internet sin filtrado estricto de egreso (*Egress Filtering*).** Los servidores del Data Center tienen permitido tráfico TCP saliente sin inspección de contenido ni resolución a través de un proxy corporativo con inspección SSL/TLS.
  - El canal se mantiene activo y camuflado simulando tráfico TLS legítimo, permitiendo al atacante ejecutar comandos de consola interactivos (`whoami`, `ipconfig`, `cat /etc/passwd`) dentro del servidor web de la universidad.

### Fase 7: Acciones sobre los Objetivos (*Actions on Objectives*)

- **Objetivo del Adversario:** Cumplimiento de la meta final que motivó el ataque cibernético.
- **Acciones del Atacante:**
  - **Pivote y Acceso a Datos Críticos:** Desde el servidor web comprometido, el atacante realiza conexiones internas hacia el motor de base de datos (ACT-01: Base de Datos Académica Central en PostgreSQL / Oracle), extrayendo cadenas de conexión almacenadas en archivos de configuración planos (`appsettings.json` o `.env`).
  - **Exfiltración de Datos Masiva:** Extracción de tablas completas que albergan DNI, nombres, domicilios, historiales académicos de estudiantes y registros de remuneraciones del personal docente, violando de forma directa la Ley N° 29733 (Ley de Protección de Datos Personales).
  - **Alteración Fraudulenta:** Modificación de actas de calificaciones, asignación fraudulenta de cupos en asignaturas colapsadas o inserción de cuentas de usuario ficticias con privilegios de administrador.
  - **Despliegue de Ransomware:** Cifrado de los discos duros virtuales de los servidores de matrícula y campus virtual con posterior extorsión económica para exigir un rescate bajo amenaza de publicar la información académica en foros de la Dark Web.

## Sec 9.3 Mapa del Ciclo de Ataque y Controles Defensivos de Interrupción

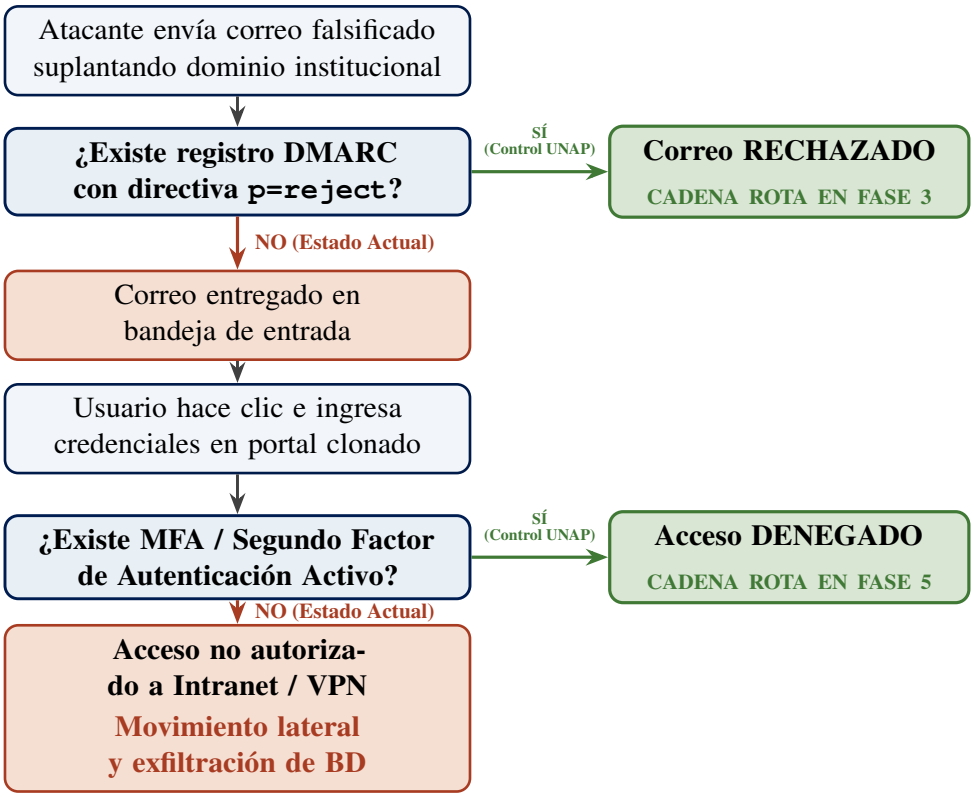
La fortaleza del enfoque defensivo radica en que la UNAP no requiere esperar a la fase final para detener al adversario. La siguiente tabla operacional define el mapa de controles preventivos, detectivos y correctivos destinados a quebrar la Kill Chain en cada eslabón:

| **Fase Cyber Kill Chain** | Acción Específica del Atacante (Escenario UNAP) | Tipo de Control | Controles Específicos para Romper el Eslabón |
|---|---|---|---|
| **1. Reconocimiento** | Escaneo pasivo de subdominios en `crt.sh` y recolección de versiones en `Server: nginx/1.16.1`. | Preventivo / Disuasivo | • Ocultamiento de cabeceras en Nginx: configurar `server_tokens off;`.<br>• Dar de baja registros DNS públicos de entornos de prueba (`dev`, `dev2`, `prue1`, `remototest`).<br>• Deshabilitar el listado de directorios en todos los servidores web institucionales. |
| **2. Armamento** | Compra de dominios tipográficos similares (`matricula-unap-edu[.]pe`) y clonación de interfaces. | Detectivo | • Servicio de Threat Intelligence para monitoreo proactivo de nuevos registros de dominios coincidentes con marcas y nombres de la UNAP.<br>• Implementación de marcas de agua dinámicas e invisibles en el código frontend oficial. |
| **3. Entrega** | Envío de correos de Spear-Phishing con remitente suplantado `@unap.edu.pe` hacia docentes. | Preventivo (Crítico) | • Publicación mandatoria de DMARC: Registrar en DNS `_dmarc.unap.edu.pe` con política estricta: `v=DMARC1;p=reject;sp=reject;rua=mailto:seguridad@unap.edu.pe`.<br>• Ajuste estricto de SPF: Reemplazar el modificador `~all` (SoftFail) por `-all` (HardFail).<br>• Firma criptográfica de correos mediante claves DKIM. |
| **4. Explotación** | El usuario hace clic en el enlace falso e introduce sus credenciales en el portal fraudulento. | Preventivo / Formativo | • Habilitación de HSTS: Forzar directiva `Strict-Transport-Security: max-age=31536000; includeSubDomains; preload` en Nginx.<br>• Pasarela de correo con análisis de enlaces en tiempo real (*Safe Links / Sandboxing*).<br>• Campañas periódicas de simulación de phishing para concientizar al personal universitario. |

| **Fase Cyber Kill Chain** | Acción Específica del Atacante (Escenario UNAP) | Tipo de Control | Controles Específicos para Romper el Eslabón |
|---|---|---|---|
| **5. Instalación** | Intento de autenticación en la VPN/intranet y subida de Web Shell en servidores web. | Preventivo (Crítico) | • Despliegue de Autenticación Multifactor (MFA): Bloquea el acceso aunque el atacante posea el usuario y contraseña.<br>• Restricción de permisos en directorios de subida web: denegar privilegios de ejecución (`noexec`) en carpetas `/uploads/` o `/assets/`.<br>• Solución EDR en servidores que bloquee la creación de procesos derivados de servidores web (ej. `nginx` o `kestrel` invocando `cmd.exe`, `sh` o `powershell`). |
| **6. Comando y Control (C2)** | Apertura de túnel reverso HTTPS desde el servidor web hacia la IP externa `194.26.29.112`. | Detectivo / Correctivo | • Filtrado estricto de egreso (*Egress Filtering*): Bloquear en Firewall perimetral tráfico saliente no autorizado desde el segmento de servidores.<br>• DNS institucional con capacidades de Sinkhole para interceptar consultas hacia dominios C2.<br>• Inspección de tráfico cifrado SSL/TLS en Firewall NGFW. |
| **7. Acción sobre el Objetivo** | Extracción masiva de bases de datos de notas, alteración de registros o cifrado por ransomware. | Correctivo / Resiliencia | • Microsegmentación Zero Trust: Aislar la Base de Datos Académica en una VLAN privada sin acceso directo desde servidores web de facultades.<br>• Cifrado en reposo (TDE / BitLocker / LUKS) y en tránsito (TLS 1.3) para los datos sensibles.<br>• Principio de mínimo privilegio en usuarios de conexión a base de datos (prohibir usuario `sa` o `postgres` en la aplicación).<br>• Estrategia de Respaldo 3-2-1: Copias de seguridad inmutables y aisladas fuera de línea (*Air-Gapped*) para garantizar recuperación total sin pagar rescates. |

## Sec 9.4 Diagrama del Punto de Quiebre Defensivo (Kill-Switch)

Al aplicar estos controles, el plan de ciberseguridad demuestra matemáticamente cómo se desarticula la cadena en sus etapas tempranas:




La implementación combinada de DMARC estricto en la Fase 3 y MFA obligatorio en la Fase 5 garantiza que, aun existiendo fallos humanos o técnicos residuales, la cadena de ataque sea desarticulada antes de comprometer los servidores centrales o las bases de datos académicas de la Universidad Nacional del Altiplano.

# 10 IMPLEMENTACIÓN DE ZERO TRUST (CONFIANZA CERO)

## Sec 10.1 Principios Rectores y Filosofía Arquitectónica en la UNAP

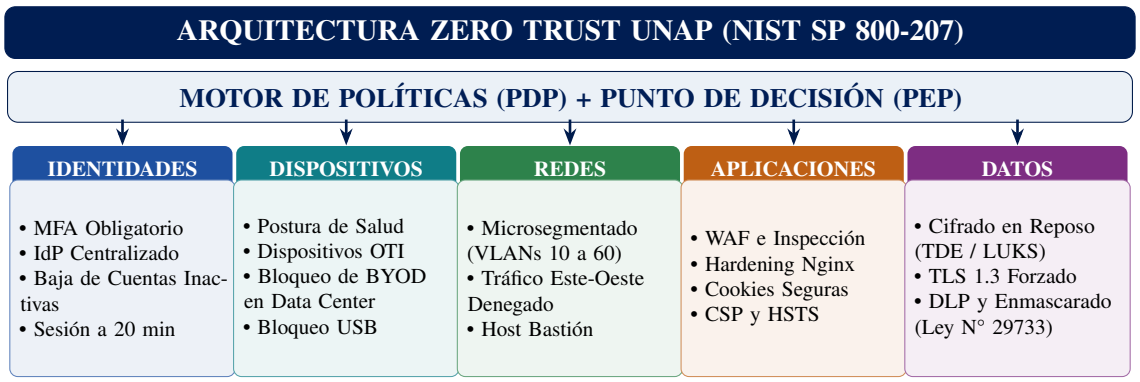
El paradigma de Confianza Cero (*Zero Trust Architecture* - ZTA), estandarizado bajo la publicación especial **NIST SP 800-207**, reemplaza de forma definitiva el modelo perimetral tradicional basado en castillos y fosos (*Castle-and-Moat*). En la infraestructura universitaria tradicional se asumía erróneamente que cualquier conexión originada dentro del campus físico (red cableada de facultades o Wi-Fi institucional) era confiable por defecto.

Bajo la doctrina Zero Trust, la Universidad Nacional del Altiplano asume como axioma operativo:

*"Nunca confiar automáticamente; verificar siempre de manera explícita y asumir la brecha (**Assume Breach**)".*

La arquitectura institucional se gobierna mediante tres principios fundamentales:

- **Verificación Explícita:** Toda solicitud de acceso a sistemas académicos o administrativos (tales como `matricula.unap.edu.pe`, `campus.unap.edu.pe`, bases de datos o consolas SSH) debe ser autenticada, autorizada y cifrada de forma continua utilizando todos los puntos de datos contextuales disponibles (identidad del usuario, robustez del método de autenticación, salud del dispositivo, ubicación de red y anomalías de comportamiento).
- **Uso del Privilegio Mínimo (*Least Privilege*):** Se limita el acceso de usuarios, cuentas de servicio y administradores mediante esquemas de acceso justo a tiempo (*Just-In-Time* - JIT) y justo el necesario (*Just-Enough-Access* - JEA), restringiendo los privilegios a las tareas estrictamente requeridas por el rol institucional.
- **Asumir la Brecha (*Assume Breach*):** Se diseña la red y los sistemas considerando que un adversario ya ha comprometido una cuenta o se encuentra ejecutando código en una estación de trabajo de una facultad. En consecuencia, se minimiza el "radio de explosión" (*blast radius*) mediante microsegmentación de redes, cifrado universal de datos y monitoreo analítico en tiempo real.



## Sec 10.2 Acciones Estratégicas por los Cinco Pilares de Zero Trust

### Pilar 1: Seguridad de las Identidades (*Users / Identities*)

La identidad constituye el nuevo perímetro defensivo de la universidad:

- **Autenticación Multifactor (MFA) Obligatoria:** Implementación universal de MFA mediante aplicaciones de contraseñas de un solo uso basadas en tiempo (TOTP como Google Authenticator o llaves de hardware FIDO2) para el 100 % de autoridades, personal administrativo, docentes y personal técnico de la OTI.
- **Directorio Unificado y Federación de Identidades (IdP / IAM):** Centralización de todas las credenciales institucionales en un único proveedor de identidad (OpenID Connect / SAML federado), eliminando bases de datos de usuarios dispersas en aplicaciones individuales.
- **Gestión de Ciclo de Vida de Cuentas:** Depuración y desactivación automatizada de cuentas de alumnos egresados, retirados y contratos concluidos de docentes y personal CAS en un plazo máximo de 48 horas tras el cese.
- **Control de Sesiones Adaptativo:** Reducción del tiempo de vida de los tokens y cookies de autenticación (`.AspNetCore.Cookies` a 20 minutos de inactividad) con reautenticación forzada ante cambios de dirección IP o huella del navegador.

### Pilar 2: Seguridad de los Dispositivos (*Devices / Endpoints*)

No se permite el acceso a servicios internos basándose únicamente en una credencial válida; el equipo debe ser verificado:

- **Validación de Postura del Dispositivo (*Device Compliance*):** Exigir que cualquier computadora que intente conectarse a la red administrativa o a la VPN cuente con sistema operativo soportado, parches de seguridad al día, firewall local activo y el agente EDR institucional operando.
- **Aislamiento de Dispositivos Personales (BYOD):** Prohibición estricta del uso de computadoras portátiles, tabletas o teléfonos personales para la administración de servidores, bases de datos o sistemas financieros (Tesorería / SITRAD). Estos dispositivos quedan confinados exclusivamente a la VLAN de navegación general.
- **Control de Periféricos:** Bloqueo de puertos USB y almacenamiento extraíble mediante directivas de grupo (GPO) y agentes EDR en estaciones de trabajo de áreas críticas (Caja, Matrícula, Data Center).



## Pilar 3: Seguridad de Redes y Comunicaciones (*Networks*)

Supresión de la red plana tradicional mediante segmentación estricta y control de flujo:

- **Microsegmentación por VLANs y Zonas de Seguridad:**
  - **VLAN 10 - Data Center / Gestión Crítica:** Aloja el motor de Base de Datos Académica (ACT-01), servidores de almacenamiento y switches Core. Aislamiento absoluto; acceso únicamente a través de un Host Bastión (*Jump Host*) con mTLS y MFA.
  - **VLAN 20 - Red Docente y Decanatos:** Segmento para equipos de catedráticos y autoridades; acceso habilitado hacia los portales web vía HTTPS, con tráfico directo denegado hacia la base de datos o consolas SSH.
  - **VLAN 30 - Red Administrativa:** Computadoras de Tesorería, SITRAD, Recursos Humanos y Matrícula. Tráfico inter-estación (este-oeste / SMB) bloqueado por firewall de capa 2/3.
  - **VLAN 40 - Laboratorios de Cómputo Estudiantiles:** Redes de alta rotación con aislamiento de clientes (*Client Isolation*); las estaciones no pueden comunicarse entre sí ni con subredes administrativas.
  - **VLAN 50 - Wi-Fi Institucional e Invitados:** Únicamente acceso de salida a Internet; aislamiento total respecto a cualquier servidor o dirección IP interna de la universidad.
  - **VLAN 60 - DMZ (Zona Desmilitarizada):** Servidores web públicos (`matricula.unap.edu.pe`, `campus.unap.edu.pe`, `www.unap.edu.pe`) protegidos por firewall perimetral y WAF.
- **Denegación por Defecto (*Default-Deny*):** Reglas en el Core Switch y Firewall NGFW que bloquean todo el tráfico entre subredes salvo que exista una regla explícita autorizada por puerto, protocolo e IP de origen/destino.
- **Filtrado Estricto de Egreso (*Egress Filtering*):** Bloqueo de todo tráfico saliente no estándar desde los servidores del Data Center para evitar comunicaciones de comando y control (C2).



## Pilar 4: Seguridad de las Aplicaciones y Cargas de Trabajo (*Applications & Workloads*)

Blindaje del software de cara a los usuarios y entre microservicios:

- **Hardening Perimetral en Reverse Proxy:** Ocultamiento mandatorio de firmas de software (`server_tokens off;` en Nginx) y actualización continua de los paquetes base para mitigar la explotación de versiones obsoletas (`nginx/1.16.1`).
- **Inyección Obligatoria de Cabeceras de Seguridad:** Activación forzada de la directiva `Strict-Transport-Security` (HSTS con `max-age=31536000`), cabeceras `X-Frame-Options: SAMEORIGIN` y directiva `X-Content-Type-Options: nosniff` en todos los portales institucionales.

- **Aseguramiento de Cookies de Sesión:** Configuración forzada en el backend ASP.NET Core y PHP de los atributos `HttpOnly`, `Secure` y `SameSite=Strict` para todas las cookies de autenticación y datos temporales (`CookieTempDataProvider`).
- **Protección mediante WAF:** Inspección activa de peticiones HTTP en tiempo real para bloquear inyecciones SQL, Cross-Site Scripting (XSS) y manipulación de parámetros de matrícula.



### Pilar 5: Seguridad de los Datos (*Data*)

Protección integral del activo más valioso de la UNAP:

- **Cifrado Mandatorio en Tránsito:** Tráfico web forzado a HTTPS bajo TLS 1.3, retirando soporte para suites de cifrado débiles o deprecadas (TLS 1.0, 1.1 y RC4).
- **Cifrado en Reposo (*Encryption at Rest*):** Cifrado de discos virtuales en el Data Center mediante BitLocker / LUKS y cifrado transparente a nivel de base de datos (*Transparent Data Encryption* - TDE) en PostgreSQL y Oracle para tablas que contengan calificaciones, historiales académicos y datos biométricos.
- **Clasificación y Enmascaramiento de Datos:** Clasificación documental conforme a la Ley N° 29733 (Datos Públicos, Uso Interno, Confidenciales y Sensibles). Enmascaramiento dinámico de datos de estudiantes y docentes en entornos de desarrollo y pruebas (`dev.unap.edu.pe`, `prue1.unap.edu.pe`).

## Sec 10.3 Matriz Institucional de Roles, Usuarios y Permisos (Modelo RBAC / Zero Trust)

La asignación de privilegios se rige por el modelo Control de Acceso Basado en Roles (RBAC) con validación contextual de políticas (*Attribute-Based Access Control* - ABAC), formalizando los accesos permitidos, niveles operativos y métodos de verificación para cada actor del ecosistema UNAP:

| **Rol Institucional** | Colectivo de Usuarios | Activos y Endpoints Autorizados | Nivel de Acceso a Base de Datos | Método de Verificación Exigido | Políticas y Restricciones Zero Trust |
|---|---|---|---|---|---|
| **Estudiante de Pregrado / Posgrado** | Más de 19,000 alumnos regulares e ingresantes | Portal de Matrícula (`/matricula/alumno/*`), Campus Virtual Moodle (`campus.unap.edu.pe`), Consulta de Notas | Lectura Restringida únicamente a su identificador de alumno (`id_alumno`). Inserción temporal en tabla de matrícula | Credenciales institucionales + MFA condicional (OTP SMS/App) + Cookie `.AspNetCore.Cookies` con flag `Secure` | • Acceso a matrícula condicionado estrictamente al cronograma académico oficial.<br>• Denegación absoluta de acceso a rutas administrativas o APIs internas de docentes.<br>• Sesión revocada tras 15 minutos de inactividad. |
| **Docente Ordinario / Contratado** | Plana docente de las 20 facultades de la UNAP | Campus Virtual Moodle, Módulo de Registro de Notas y Asistencia Docente (`/docente/*`) | Lectura de nómina de alumnos inscritos en su carga horaria. Escritura en actas de evaluación académica | Cuenta institucional unificada (`@unap.edu.pe`) + MFA Obligatorio (TOTP) | • Inserción de notas permitida únicamente dentro de las fechas de apertura de actas fijadas por el Vicerrectorado Académico.<br>• Prohibido el acceso directo al sistema operativo o a consolas de administración del servidor.<br>• Registro auditado e inmutable de cada cambio de nota con IP y timestamp. |
| **Director de Escuela Profesional** | Directores de las 36 Escuelas Profesionales | Módulo de Gestión Curricular, Apertura de Grupos y Convalidaciones | Lectura de padrones de la escuela. Modificación de cupos y horarios correspondientes a su carrera | Credenciales nominativas + MFA obligatorio + Acceso condicionado a IP o red institucional | • Aprobación de ampliación de vacantes o convalidaciones sujeta a firma digital institucional.<br>• Restricción geográfica: denegación de accesos directivos desde fuera del territorio nacional sin preaviso a la OTI. |

## 10.3. MATRIZ INSTITUCIONAL DE ROLES, USUARIOS Y PERMISOS (MODELO RBAC / ZERO TRUST)

| **Rol Institucional** | Colectivo de Usuarios | Activos y Endpoints Autorizados | Nivel de Acceso a Base de Datos | Método de Verificación Exigido | Políticas y Restricciones Zero Trust |
|---|---|---|---|---|---|
| **Operador de Tesorería y Caja** | Personal administrativo de la DGA | Sistema de Recaudación, Facturación Electrónica y Conciliaciones (`tesoreria.unap.edu.pe`) | Lectura y Escritura en tablas de transacciones financieras y estados de pago de tasas | Credencial nominativa única (no compartida) + MFA + Certificado de equipo instalado | • Acceso permitido exclusivamente desde estaciones de trabajo corporativas dentro de la VLAN 30 (Red Administrativa).<br>• Denegación total de acceso vía Wi-Fi, VPN doméstica o Internet público.<br>• Bloqueo de puertos USB y almacenamiento extraíble en la PC. |
| **Operador de Mesa de Partes / Trámite** | Personal de Trámite Documentario y Archivo Central | Sistema de Trámite Documentario (SITRAD / `tramiteapp.unap.edu.pe`) | Lectura y Creación de expedientes, decretos y resoluciones universitarias | Credencial institucional + MFA + Firma Digital (Reniec / Refirma) | • Segmentación estricta de expedientes por áreas de derivación autorizadas.<br>• Trazabilidad total de descargas de documentos clasificados como confidenciales. |
| **Desarrollador de Sistemas OTI** | Ingenieros de software y programadores de la OTI | Repositorios Git institucionales, Servidores de Pruebas y Homologación (`dev.*`, `prue1.*`) | Lectura y Escritura en bases de datos de desarrollo (con datos ficticios o enmascarados) | Autenticación basada en llaves SSH (RSA 4096 / Ed25519) + MFA | • Prohibición absoluta de desplegar entornos `dev` o `prue1` con acceso directo a Internet. Deben operar en subred privada detrás de VPN.<br>• Prohibido el uso de credenciales de producción en código fuente o repositorios. |
| **Administrador de Redes y Comunicaciones** | Ingenieros de la Unidad de Redes OTI | Consolas de gestión de Switches Core, Routers, Controladores Wi-Fi y Firewall UTM | Nulo acceso a datos de negocio; acceso total a tablas de enrutamiento y configuraciones | Cuenta nominal de administración + Llave física FIDO2 / Token de hardware | • Acceso permitido únicamente desde el Host Bastión (*Jump Host*) en la VLAN 10.<br>• Todas las sesiones SSH/HTTPS quedan grabadas en video y bitácora centralizada.<br>• Prohibido el uso de la cuenta genérica `admin` de los equipos. |

| **Rol Institucional** | Colectivo de Usuarios | Activos y Endpoints Autorizados | Nivel de Acceso a Base de Datos | Método de Verificación Exigido | Políticas y Restricciones Zero Trust |
|---|---|---|---|---|---|
| **Administrador de Base de Datos (DBA)** | Custodio de Bases de Datos de la OTI | Motores de bases de datos centrales (PostgreSQL, Oracle, SQL Server en Data Center) | Control Total (DBA) sobre esquemas, procedimientos almacenados, usuarios de BD y respaldos | Autenticación mutua (mTLS) + Cuenta nominal DBA + MFA en servidor bastión | • Conexión TCP directa hacia el puerto de base de datos bloqueada para cualquier equipo que no sea el servidor de aplicaciones o el Bastión.<br>• Consultas masivas (`SELECT *`, `DROP`, `ALTER`) alertadas inmediatamente en el SIEM.<br>• Respaldo y cifrado obligatorio de llaves de recuperación. |

## Sec 10.4 Procedimiento Operativo de Verificación y Revocación de Accesos

Para asegurar la sostenibilidad del modelo Zero Trust en el tiempo, la OTI ejecutará tres rutinas operativas periódicas:

- **Revisión Trimestral de Cuentas y Privilegios (*Access Review*):** Auditoría automatizada que cruza el padrón activo de personal provisto por Recursos Humanos con los directorios de usuarios. Toda cuenta sin justificación de rol vigente o con más de 60 días sin actividad transaccional es suspendida inmediatamente.
- **Revocación Inmediata de Permisos (*Kill-Switch* de Identidad):** Ante la detección de una anomalía de seguridad por el SIEM (ej. intento de acceso desde una ubicación geográfica imposible o reporte de robo de equipo), el centro de operaciones invocará un script de respuesta rápida que invalida los tokens de sesión activos en Redis/ASP.NET Core, bloquea la cuenta en el directorio unificado y corta las conexiones VPN activas del usuario en menos de 60 segundos.
- **Monitoreo Continuo de Comportamiento (*User and Entity Behavior Analytics* - UEBA):** Monitoreo algorítmico de desviaciones en los patrones de uso habituales de los trabajadores universitarios (ej. un docente intentando modificar actas de notas a las 03:00 AM o un operador de tesorería descargando volúmenes atípicos de registros de pago). Toda desviación genera una alerta de severidad Alta que exige verificación telefónica o reautenticación mediante MFA con confirmación de número (*Number Matching*).

# 11

# MATRIZ DE GESTIÓN Y GOBERNANZA – NIST CSF 2.0

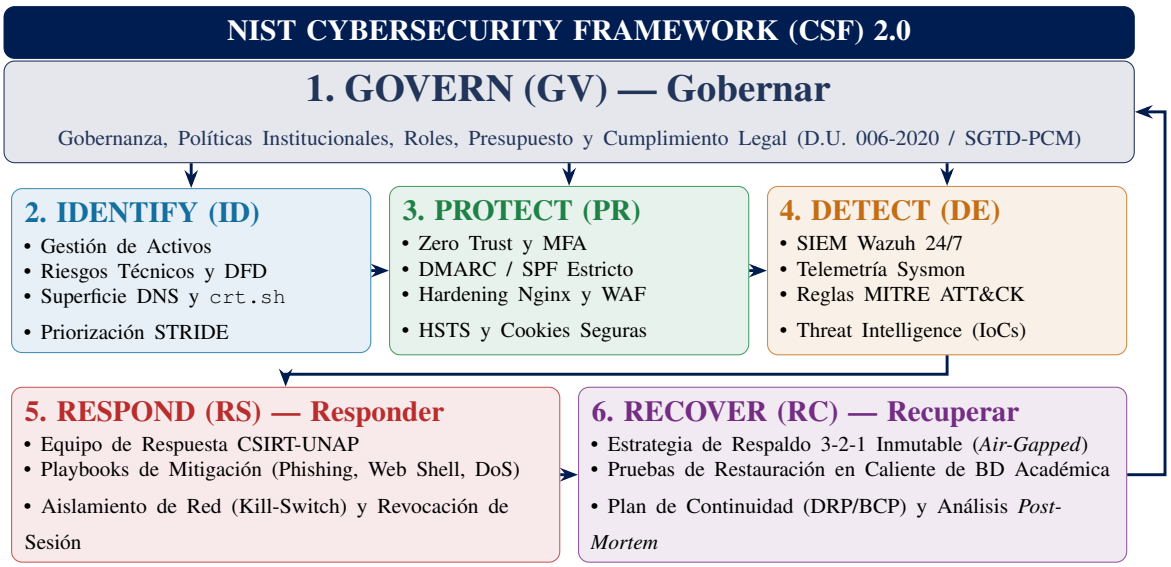
## Sec 11.1 Fundamentación del Marco NIST CSF 2.0 en la UNAP

El Marco de Ciberseguridad del NIST (*NIST Cybersecurity Framework* - Versión 2.0) actúa como el modelo sombrilla de gobernanza estratégica y operativa del presente plan. A diferencia de su versión previa (1.1), el NIST CSF 2.0 incorpora formalmente la función transversal **Gobernar (*Govern* - GV)**, reconociendo que la ciberseguridad no es un problema puramente técnico del área de TI, sino una disciplina directiva vinculada al riesgo institucional, la asignación presupuestal y el marco legal del Estado peruano (D.U. N° 006-2020 y directivas de la SGTD/PCM).

En la Universidad Nacional del Altiplano de Puno, el NIST CSF 2.0 orquesta las metodologías tácticas aplicadas previamente:

- Proporciona el marco directivo para priorizar las amenazas descubiertas con STRIDE en el sistema de matrícula.
- Institucionaliza la ingestión de *Threat Intelligence* y el monitoreo de TTPs catalogadas en MITRE ATT&CK.
- Provee la estructura de resiliencia para quebrar la *Cyber Kill Chain* y materializar los controles de Zero Trust.

El marco organiza la gestión institucional en seis funciones continuas:



## Sec 11.2 Matriz Integral NIST CSF 2.0 Aplicada a la UNAP

La siguiente matriz desglosa formalmente las acciones, controles específicos, responsables institucionales y herramientas tecnológicas para cada una de las seis funciones de ciberseguridad:

| **Función NIST 2.0** | Categoría / Subcategoría | Acciones a Desarrollar en la UNAP | Controles Implementados | Responsables | Herramientas y Tecnologías Sugeridas |
|---|---|---|---|---|---|
| **1. GOVERN (GV)** ***Gobernar*** | Estrategia y Contexto (GV.SC)<br>Supervisión de Riesgo (GV.RM)<br>Cumplimiento Legal (GV.PO) | • Formalizar el Comité de Gobierno de Seguridad Digital de la UNAP.<br>• Aprobar mediante Resolución Rectoral la Política Institucional de Seguridad de la Información.<br>• Alinear la gestión universitaria con el D.U. 006-2020, Ley 30096 (Delitos Informáticos) y Ley 29733 (Datos Personales).<br>• Asignar presupuesto anual específico para licencias de seguridad, renovación de infraestructura y capacitación. | • Creación del rol formal de Oficial de Seguridad de la Información (CISO / Delegado de Seguridad Digital).<br>• Política obligatoria de uso aceptable de recursos tecnológicos y redes.<br>• Acuerdos de confidencialidad (NDA) para desarrolladores y contratistas de la OTI. | • Rectorado<br>• Consejo Universitario<br>• Asesoría Legal<br>• Jefe de la OTI / CISO | • Sistema de Gestión Documental (ISO 27001 doc)<br>• Plataforma de Trámite SITRAD |
| **2. IDENTIFY (ID)** ***Identificar*** | Gestión de Activos (ID.AM)<br>Evaluación de Riesgos (ID.RA)<br>Mejora Continua (ID.IM) | • Mantener actualizado el inventario de hardware, servidores, bases de datos y los más de 100 subdominios públicos.<br>• Identificar dependencias críticas entre el sistema de matrícula (`matricula.unap.edu.pe`), Nginx y la base de datos PostgreSQL/Oracle.<br>• Ejecutar modelado periódico de amenazas con STRIDE y clasificar activos por criticidad (1 al 4). | • Matriz de inventario de activos TI con clasificación de datos sensibles.<br>• Relevamiento pasivo bimestral de certificados SSL/TLS y dominios en `crt.sh`.<br>• Evaluación de riesgo técnico basada en el método DREAD adaptado. | • Administradores de Red y Sistemas OTI<br>• Custodio de Base de Datos<br>• Gestor de Inventario TI | • Snipe-IT (Gestor de inventario TI Open Source)<br>• `crt.sh` / Amass (Mapeo de subdominios)<br>• Microsoft Threat Modeling Tool / Draw.io |
| **3. PROTECT (PR)** ***Proteger*** | Gestión de Identidad (PR.AA)<br>Seguridad de Datos (PR.DS)<br>Mantenimiento (PR.MA) | • Desplegar arquitectura Zero Trust en toda la infraestructura universitaria.<br>• Endurecer la seguridad en el transporte web mediante HSTS y actualización de `nginx/1.16.1`.<br>• Blindar el vector de correo electrónico corrigiendo las directivas DNS institucionales.<br>• Asegurar la persistencia de cookies en ASP.NET Core (`HttpOnly`, `Secure`, `SameSite=Strict`). | • DMARC mandatorio: Publicación en DNS de `_dmarc.unap.edu.pe` con `p=reject`.<br>• SPF estricto: Modificar directiva final de `ãll` a `-all`.<br>• MFA Obligatorio: TOTP / FIDO2 para docentes y personal administrativo.<br>• Microsegmentación: Aislamiento de VLANs (10 Data Center, 20 Docentes, 30 Admin, 40 Labs, 60 DMZ).<br>• Directivas HSTS con `max-age=31536000; includeSubDomains`. | • Administrador de Redes y Comunicaciones<br>• Administrador Web / Proxy<br>• Desarrolladores Backend OTI | • Fortinet FortiGate / pfSense (NGFW)<br>• Nginx Hardening (`server_tokens off;`)<br>• Google Workspace Admin / FreeIPA (IdP)<br>• Let's Encrypt / Certbot (TLS 1.3) |

| Función NIST 2.0 | Categoría / Subcategoría | Acciones a Desarrollar en la UNAP | Controles Implementados | Responsables | Herramientas y Tecnologías Sugeridas |
|---|---|---|---|---|---|
| **4. DETECT (DE)** ***Detectar*** | Monitoreo Continuo (DE.CM)<br>Análisis de Adversarios (DE.AE) | • Centralizar la recolección de eventos de seguridad (logs web, autenticaciones, firewalls, DNS).<br>• Monitorear activamente las TTPs mapeadas en MITRE ATT&CK (ej. T1059 PowerShell, T1505 Web Shells, T1078 Cuentas Válidas).<br>• Correlacionar accesos sospechosos contra bases de datos de Threat Intelligence (IoCs). | • Despliegue de agentes EDR/SIEM en el 100 % de servidores y estaciones administrativas.<br>• Alertas por inicios de sesión simultáneos imposibles o fuerza bruta en portales web.<br>• Monitoreo de integridad de archivos web (FIM) en directorios de carga (`/uploads/`). | • Operadores del SOC-UNAP<br>• Analista de Ciberseguridad OTI | • Wazuh SIEM (XDR & Log Analysis)<br>• Sysmon (Monitoreo de eventos Windows)<br>• Suricata / Snort (IDS de Red)<br>• AlienVault OTX / AbuseIPDB (Feeds IoCs) |
| **5. RESPOND (RS)** ***Responder*** | Plan de Respuesta (RS.MA)<br>Mitigación de Incidentes (RS.MI)<br>Comunicación (RS.CO) | • Conformar y activar el Equipo de Respuesta a Incidentes de Seguridad Digital (CSIRT-UNAP).<br>• Ejecutar playbooks estandarizados ante incidentes de phishing masivo, ransomware, compromiso de cuentas o DoS.<br>• Aislar de inmediato estaciones comprometidas y revocar tokens de sesión activos (`.AspNetCore.Cookies`).<br>• Notificar incidentes de impacto nacional al Centro Nacional de Seguridad Digital (CSIRT-PE / PCM). | • Procedimiento formal de gestión de incidentes en 6 etapas.<br>• Protocolo de aislamiento lógico de red (Kill-Switch en switches Core y Firewall).<br>• Revocación masiva de sesiones y reseteo forzado de credenciales en Active Directory/Google Workspace.<br>• Canal oficial de reporte: `seguridad.informatica@unap.edu.pe`. | • Comité CSIRT-UNAP<br>• Jefe de OTI / CISO<br>• Administrador de Redes<br>• Unidad de Comunicaciones | • TheHive / Cortex (Gestión de Incidentes)<br>• Scripts de aislamiento automatizado (PowerShell / Bash / API Firewall)<br>• Plantillas de notificación oficial |
| **6. RECOVER (RC)** ***Recuperar*** | Plan de Restauración (RC.RP)<br>Lecciones Aprendidas (RC.CO) | • Garantizar la recuperación total de los sistemas académicos y financieros ante desastres o ataques de secuestro de datos.<br>• Validar la integridad y consistencia de las bases de datos de matrícula antes de la reactivación del servicio.<br>• Elaborar el informe de lecciones aprendidas (*Post-Mortem*) tras cada incidente relevante para alimentar el ciclo de gobernanza. | • Estrategia de Respaldo 3-2-1: 3 copias de datos, en 2 medios diferentes, 1 copia aislada fuera de línea (*Air-Gapped* / Inmutable).<br>• Pruebas semestrales de restauración en caliente de la Base de Datos Académica Central.<br>• Plan de Continuidad Operativa y Recuperación ante Desastres (BCP / DRP). | • Administrador de Bases de Datos (DBA)<br>• Administrador de Infraestructura y Servidores<br>• Jefe de la OTI | • Veeam Backup & Replication / BorgBackup<br>• Almacenamiento NAS/SAN dedicado con snapshots WORM (*Write-Once-Read-Many*)<br>• Entorno de *Staging* para validación limpia |

## Sec 11.3 Articulación Operativa con las Metodologías del Plan

Para evidenciar la coherencia técnica exigida por la estructura del proyecto, la siguiente relación causal demuestra cómo interactúan las herramientas dentro del marco NIST CSF 2.0:

**GOVERN** $\longrightarrow$ Define las políticas institucionales, presupuesto y roles (CISO / OTI).
**IDENTIFY** $\longrightarrow$ STRIDE descubre fallas en el DFD de matrícula y clasifica los activos.
**PROTECT** $\longrightarrow$ Zero Trust aplica controles: MFA, HSTS, DMARC $(p = \text{reject})$ y VLANs.
**DETECT** $\longrightarrow$ Threat Intelligence aporta IoCs y MITRE ATT&CK define reglas SIEM.
**RESPOND** $\longrightarrow$ Cyber Kill Chain guía el corte del vector vía playbooks CSIRT-UNAP.
**RECOVER** $\longrightarrow$ Estrategia 3-2-1 y análisis *Post-Mortem* garantizan continuidad y mejora.

Esta integración asegura que la Universidad Nacional del Altiplano disponga de un plan estructurado, verificable y alineado con los más altos estándares internacionales de ciberseguridad.

# 12 CONTROLES TÉCNICOS DE SEGURIDAD

En este capítulo se detallan las especificaciones técnicas y el catálogo de implementación de los controles de seguridad seleccionados para blindar el entorno tecnológico de la UNAP.

## Sec 12.1 Catálogo de Especificación Técnica de Controles

1. **Control de Identidad y Acceso:** Implementación generalizada de Autenticación Multifactor (MFA) sobre un esquema de Inicio de Sesión Único (Single Sign-On - SSO) corporativo basado en OpenID Connect / SAML 2.0.

2. **Seguridad Perimetral y de Aplicación:** Despliegue de un Firewall de Siguiente Generación (Next-Generation Firewall - NGFW) en el borde y un Web Application Firewall (WAF) perimetral para inspección de peticiones HTTP/HTTPS (bloqueo de inyecciones SQL, XSS y ataques L7).

3. **Seguridad en Endpoints:** Instalación de agentes de Endpoint Detection and Response (EDR) centralizados en todas las estaciones administrativas y servidores del Data Center para detección de comportamientos anómalos.

4. **Cifrado Criptográfico Estricto:** Forzado del protocolo TLS 1.3 en todos los portales web institucionales, desactivación definitiva de suites criptográficas débiles (SSLv3, TLS 1.0, TLS 1.1) y cifrado de volúmenes de almacenamiento mediante LUKS / BitLocker.

5. **Monitoreo y Auditoría Centralizada:** Plataforma SIEM (Security Information and Event Management) basada en Wazuh para agregación, correlación y análisis de registros de eventos en tiempo real.

6. **Microsegmentación de Redes:** Reglas estrictas de filtrado de tráfico inter-VLAN en el Switch Core central, impidiendo que el tráfico de alumnos acceda a servidores de bases de datos o redes administrativas.

7. **Gestión Continua de Vulnerabilidades:** Ejecución de escaneos periódicos programados mediante OpenVAS / Nessus para identificación y remediación temprana de fallas en servidores y servicios expuestos.

8. **Continuidad Operativa y Respaldos Inmutables:** Automatización de copias de seguridad de bases de datos con retención histórica y almacenamiento inmutable fuera de línea.

## Sec 12.2 Configuración de Endurecimiento Web en Servidores Nginx

A continuación, se presenta la directiva de configuración recomendada para mitigar los hallazgos de información expuesta y falta de HSTS:

**>_ | Configuración Nginx para Hardening (security.conf)**

```
# Desactivar version de servidor
server_tokens off;

# Cabeceras de proteccion obligatorias
add_header Strict-Transport-Security 'max-age=31536000; includeSubDomains'
    always;
add_header X-Frame-Options 'SAMEORIGIN' always;
add_header X-Content-Type-Options 'nosniff' always;
add_header X-XSS-Protection '1; mode=block' always;
add_header Content-Security-Policy 'default-src \'self\';' always;

# Forzar TLS 1.2 y 1.3 unicamente
ssl_protocols TLSv1.2 TLSv1.3;
ssl_prefer_server_ciphers on;
```

# 13 GESTIÓN Y RESPUESTA A INCIDENTES

En este capítulo se describe el procedimiento operativo estándar para la gestión, contención y recuperación ante eventos o incidentes de seguridad que afecten a la UNAP.

## Sec 13.1 Procedimiento Operativo Estándar

El ciclo de vida de atención a incidentes de seguridad digital sigue la secuencia estándar de seis fases:

**Detección** $\longrightarrow$ **Análisis y Triaje** $\longrightarrow$ **Contención**
$\longrightarrow$ **Erradicación** $\longrightarrow$ **Recuperación** $\longrightarrow$ **Evaluación Post-Mortem**

1. **Detección:** Identificación de alertas a través del SIEM, reportes de usuarios o anomalías en el tráfico de red.
2. **Análisis y Triaje:** Determinación del alcance, impacto potencial y severidad del incidente por parte del equipo CSIRT-UNAP.
3. **Contención:** Aplicación de medidas de aislamiento inmediato (aislamiento de VLAN, revocación de tokens, bloqueo perimetral de IPs) para evitar la propagación.
4. **Erradicación:** Eliminación de artefactos maliciosos, cierre de brechas de configuración y revocación de credenciales comprometidas.
5. **Recuperación:** Restauración de servicios a partir de respaldos limpios validados y reactivación paulatina con monitoreo reforzado.
6. **Evaluación Posterior (Post-Mortem):** Elaboración del informe técnico final, identificación de lecciones aprendidas y ajuste de controles preventivos.

## Sec 13.2 Canales Institucionales de Notificación Rápida

Para garantizar la oportuna recepción de reportes sobre comportamientos anómalos, se formalizan los siguientes canales oficiales:

- **Correo Electrónico de Seguridad:** `seguridad.informatica@unap.edu.pe`
- **Anexo Telefónico de Emergencia OTI:** Anexo interno 1111 (Línea directa del CSIRT-UNAP).
- **Botón de Reporte en Webmail:** Complemento integrado en el correo institucional para notificar mensajes sospechosos de phishing en un clic.

## Sec 13.3 Clasificación de Incidentes por Tipo de Amenaza

- **Phishing Masivo o Dirigido:** Correos fraudulentos que buscan robar identidades o distribuir malware.
- **Accesos No Autorizados:** Intentos de inicio de sesión anómalos o explotación de credenciales institucionales.
- **Infecciones por Malware / Ransomware:** Ejecución de código malicioso en servidores o computadoras de oficinas.
- **Exfiltración de Información:** Fuga o extracción no autorizada de bases de datos o expedientes sensibles.
- **Pérdida o Sustracción de Equipos Físicos:** Extravío de portátiles o almacenamiento institucional con datos sensibles.

# 14 CAPACITACIÓN Y CONCIENTIZACIÓN

En este capítulo se establece el programa integral de concientización y formación en seguridad digital para toda la comunidad universitaria.

## Sec 14.1 Campaña Permanente de Concientización

Se implementará un plan continuo de sensibilización enfocado en mitigar el factor humano como vector de ataque:

- **Ingeniería Social y Phishing:** Talleres prácticos para reconocer correos apócrifos, enlaces sospechosos y técnicas de manipulación psicológica.
- **Contraseñas Robustas y Gestión de Identidad:** Uso de contraseñas de alta entropía, adopción de gestores de contraseñas y activación obligatoria de MFA.
- **Manejo Seguro de Medios Extraíbles (USB):** Protocolos para evitar la conexión de dispositivos USB desconocidos en computadoras institucionales.
- **Navegación Segura y Protección de Datos:** Pautas para identificar certificados HTTPS válidos y evitar el ingreso de credenciales en redes Wi-Fi públicas.

## Sec 14.2 Simulaciones Semestrales de Phishing Controlado

La OTI ejecutará ejercicios semestrales de simulación de phishing no destructivo hacia el personal docente y administrativo, con el objetivo de medir la susceptibilidad institucional, capacitar en tiempo real a los usuarios que caigan en el señuelo y evaluar la tasa de reporte voluntario.

## Sec 14.3 Módulos de Formación Especializada para Personal Técnico

Dirigidos a los administradores de sistemas, redes y desarrolladores de software de la OTI:

- **Desarrollo Seguro de Software (OWASP Top 10):** Técnicas de codificación defensiva, sanitización de entradas, prevención de inyecciones SQL/XSS y validación de APIs REST.
- **Hardening de Infraestructura:** Configuración segura de servidores web Nginx/Apache, bastionado de sistemas operativos Linux y gestión segura de bases de datos.

- **Análisis de Logs y Cacería de Amenazas (Threat Hunting):** Uso avanzado de consolas SIEM para la identificación de anomalías y respuesta a intrusiones.

# 15 INDICADORES DE CUMPLIMIENTO (MÉTRICAS Y KPIS)

En este capítulo se establecen las métricas e Indicadores Clave de Desempeño (KPIs) para evaluar cuantitativamente la eficacia, madurez y avance del plan de ciberseguridad.

## Sec 15.1 Cuadro de Mando de Métricas de Ciberseguridad

Los siguientes indicadores serán reportados trimestralmente al Comité de Gobierno Digital de la UNAP:

| **Indicador / Métrica** | Fórmula de Cálculo | Meta Esperada | Frecuencia |
|---|---|---|---|
| **Porcentaje de activos inventariados** | $\frac{\text{Act. Catalogados}}{\text{Act. Totales}} \times 100$ | $\geq 98\,\%$ | Mensual |
| **Cobertura de evaluación STRIDE** | $\frac{\text{Sist. Modelados}}{\text{Sist. Críticos}} \times 100$ | $100\,\%$ | Semestral |
| **Remediación de fallas críticas** | Tiempo promedio de resolución de hallazgos | $< 72$ horas | Continuo |
| **Cuentas con MFA activo** | $\frac{\text{Cuentas con MFA}}{\text{Total Cuentas}} \times 100$ | $100\,\%$ | Mensual |
| **Tasa de clics en phishing** | $\frac{\text{Clics Phishing}}{\text{Total Evaluados}} \times 100$ | $\leq 8\,\%$ | Semestral |
| **Tiempo medio de detección (MTTD)** | Promedio de horas transcurridas desde el evento | $< 2$ horas | Mensual |
| **Tiempo medio de respuesta (MTTR)** | Promedio de horas para contención efectiva | $< 4$ horas | Mensual |
| **Éxito en restauración de backups** | $\frac{\text{Ensayos Exitosos}}{\text{Total Ensayos}} \times 100$ | $100\,\%$ | Semestral |

# ANEXOS: EVIDENCIAS Y DOCUMENTACIÓN DE SOPORTE

En esta sección se compilan las matrices técnicas, evidencias operativas y formatos de gestión que sustentan el plan de ciberseguridad.

## Sec Anexo 1: Inventario de Activos (Mapeo OSINT)

Tabla consolidada de los subdominios y servidores identificados mediante fuentes abiertas (`crt.sh` y DNS):

| Subdominio Identificado | Dirección IP | Registro SSL / Origen | Estado Operativo |
|---|---|---|---|
| `matricula.unap.edu.pe` | 161.132.24.61 | Let's Encrypt Authority | Activo (Producción) |
| `campus.unap.edu.pe` | 161.132.24.62 | Let's Encrypt Authority | Activo (Producción) |
| `sitrad.unap.edu.pe` | 161.132.24.63 | cPanel / Sectigo SSL | Activo (Administrativo) |
| `repositorio.unap.edu.pe` | 161.132.24.64 | GlobalSign Root CA | Activo (Académico) |
| `dev.unap.edu.pe` | 161.132.24.70 | Certificado autofirmado | Riesgo (Entorno Dev) |
| `prue1.unap.edu.pe` | 161.132.24.71 | Certificado expirado | Riesgo (Entorno Legado) |

## Sec Anexo 2: Matriz de Criticidad de Activos (Tríada CIA)

Calificación de impacto institucional basada en Confidencialidad (C), Integridad (I) y Disponibilidad (A):

| Activo Tecnológico | Confidencialidad | Integridad | Disponibilidad | Nivel Consolidado |
|---|---|---|---|---|
| **Base de Datos Central** | Muy Alto | Muy Alto | Muy Alto | **Crítico** |
| **Sistema de Matrícula** | Alto | Muy Alto | Muy Alto | **Crítico** |
| **Campus Virtual Moodle** | Medio | Alto | Muy Alto | **Crítico** |
| **Correo Institucional** | Muy Alto | Alto | Alto | **Alto** |
| **Portal Web de Facultades** | Bajo | Medio | Medio | **Medio** |

## Sec Anexo 3: Matriz STRIDE y Evidencias Técnicas

- **Diagrama de Flujo de Datos (DFD Nivel 1):** Navegador Cliente ↔ Reverse Proxy Nginx ↔ Backend ASP.NET Core ↔ Base de Datos.

- **Captura de Cabeceras HTTP (DevTools F12):** Exposición pública de la versión del servidor web en `matricula.unap.edu.pe`:

**>_ | Evidencia F12: Cabeceras HTTP en matricula.unap.edu.pe**

```
HTTP/1.1 200 OK
Server: nginx/1.16.1
Date: Sat, 17 Oct 2026 15:20:00 GMT
Content-Type: text/html; charset=utf-8
Set-Cookie: .AspNetCore.Cookies=CfDJ8...; path=/; HttpOnly; SameSite=Lax
# NOTA: Ausencia de cabecera Strict-Transport-Security (HSTS desactivado)
# NOTA: La bandera 'Secure' no se encuentra forzada en todas las cookies
```

## Sec Anexo 4: Matriz MITRE ATT&CK y Configuración de Reglas

Mapeo sistemático de técnicas adversarias y correspondencia con reglas de detección en el SIEM institucional Wazuh.

## Sec Anexo 5: Cyber Kill Chain y Evidencias de Dominio

- **Flujograma del ataque en 7 etapas:** Reconocimiento → Armamento → Entrega → Explotación → Instalación → C2 → Objetivos.

- **Evidencia DNS de vulnerabilidad en correo institucional:**

**>_ | Evidencia DNS: Registros DMARC y SPF en unap.edu.pe**

```
$ host -t txt _dmarc.unap.edu.pe
Host _dmarc.unap.edu.pe not found: 3(NXDOMAIN)

$ host -t txt unap.edu.pe
unap.edu.pe descriptive text 'v=spf1 ip4:161.132.24.0/24 include:_spf.
    google.com ~all'
```

## Sec Anexo 6: Matriz Zero Trust y Postura de Red

- **Negociación TLS en campus.unap.edu.pe:** Inspección de certificados que confirma ausencia de precarga HSTS.
- **Esquema de Microsegmentación:** Aislamiento de VLAN 10 (Servidores), VLAN 20 (Administración), VLAN 30 (Docencia), VLAN 40 (Alumnos) y VLAN 60 (Wi-Fi Invitados).

## Sec Anexo 7: Registro de Incidentes (Boleta Formal)

Formato estandarizado para la notificación interna y reporte formal ante el CSIRT-UNAP con campos de fecha, reportante, activo afectado, criticidad y vector preliminar.

## Sec Anexo 8: Cronograma Anual de Implementación

Plan de trabajo estructurado a 12 meses (Fase 1: Diagnóstico e inventario; Fase 2: Despliegue de MFA y WAF; Fase 3: Hardening y SIEM; Fase 4: Auditoría y simulaciones de phishing).

## Sec Anexo 9: Cuadro de Mando de Indicadores

Matriz de seguimiento de KPIs operativos (MTTD $< 2$ h, MTTR $< 4$ h, $100\,\%$ de cuentas docentes con MFA).

## Sec Anexo 10: Plan de Capacitación y Concientización

Calendario temático semestral de talleres para docentes, alumnos y módulos especializados para el equipo técnico de la OTI en OWASP Top 10.

# BIBLIOGRAFÍA


Congreso de la Republica del Peru. Ley nro. 29733: Ley de proteccion de datos personales y su reglamento, 2011.

FIRST. Common vulnerability scoring system v3.1: Specification document, 2019.

Michael Howard and David LeBlanc. *Writing Secure Code*. Microsoft Press, Redmond, WA, 2nd edition, 2003.

Eric M Hutchins, Michael J Cloppert, and Rohan M Amin. Intelligence-driven computer network defense informed by analysis of adversary campaigns and intrusion kill chains. *Leading Issues in Information Warfare & Security Research*, 1(1):80–106, 2011.

ISO/IEC. Iso/iec 27001:2022 information security, cybersecurity and privacy protection — information security management systems — requirements, 2022.

Loren Kohnfelder and Praerit Garg. The threats to our products. Technical report, Microsoft Corporation, 1999. Microsoft Interface Security Report.

J. D. Meier, Alex Mackman, Michael Dunner, Srinath Vasireddy, Ray Escamilla, and Anand Murukan. Improving web application security: Threats and countermeasures. Technical report, Microsoft Corporation, 2003.

NIST. Guide for conducting risk assessments. Technical report, NIST Special Publication 800-30 Revision 1, 2012.

NIST. Framework for improving critical infrastructure cybersecurity (version 1.1). Technical report, National Institute of Standards and Technology, 2018.

OWASP Foundation. Threat modeling cheat sheet. Technical report, Open Web Application Security Project, 2020.

OWASP Foundation. Owasp top 10: 2021 - the ten most critical web application security risks. Technical report, Open Web Application Security Project, 2021.

Karen Scarfone, Murugiah Souppaya, Amanda Cody, and Angela Orebaugh. Technical guide to information security testing and assessment. Technical report, NIST Special Publication 800-115, 2008.

Adam Shostack. *Threat Modeling: Designing for Security*. John Wiley & Sons, Indianapolis, IN, 2014.

William Stallings. *Cryptography and Network Security: Principles and Practice*. Pearson, 7th edition, 2018.

The MITRE Corporation. Mitre att&ck enterprise matrix for web applications, 2023.